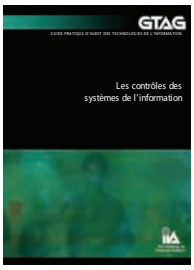
GTAG®

GUIDE PRATIQUE D'AUDIT DES TECHNOLOGIES DE L'INFORMATION

Gestion de la continuité d'activité

The Institute of Internal Auditors

Cette série de guides, rédigés dans des termes simples et traitant chacun d'un thème d'actualité concernant la gestion, le contrôle et la sécurité des SI, constitue un précieux outil pour les responsables de l'audit interne, qui peuvent ainsi s'informer sur les différents risques associés aux technologies de l'information et sur les pratiques recommandées.



Les contrôles des systèmes de l'information
Les sujets abordés passent en revue les concepts du contrôle des SI, l'importance de ces contrôles, les rôles et responsabilités dans l'organisation susceptibles d'assurer l'efficacité du contrôle des SI et des techniques de surpervision.

Contrôles de la gestion du changement et des patchs : un facteur clé de la réussite pour toute organisation
Décrit les sources de changements et leurs impacts probables sur les objectifs de l'entreprise, explique en quoi le contrôle du processus de gestion des changements participe à la réduction des risques et des coûts des SI, et indique ce qui, dans la pratique, fonctionne ou pas.

Audit continu : Répercussions sur l'assurance, le pilotage et l'évaluation des risques
Traite du rôle de l'audit continu dans l'environnement actuel d'audit interne, de la relation entre audit continu, surveillance continue et assurance continue, précise où s'applique l'audit continu et examine la mise en place de l'audit continu.

Management de l'audit des systèmes d'information
Définit les risques liés aux SI et l'univers d'audit, explique comment conduire un audit des SI et gérer les ressources d'audit.

Le management et l'audit des risques d'atteinte à la vie privée
Présente les principes et le cadre de protection de la vie privée, un modèle de risques d'atteinte à la vie privée et le contrôle du respect de la vie privée, le rôle de l'audit interne, les dix questions à se poser concernant la protection de la vie privée lors de la mission d'audit, et bien plus encore.

Gérer et auditer les vulnérabilités des technologies de l'information
Analyse, entre autres, le cycle de gestion des vulnérabilités, la délimitation de l'audit des vulnérabilités et des indicateurs qui permettent d'évaluer les pratiques de gestion des vulnérabilités.

L'infogérance
Examine comment choisir le bon prestataire de services d'infogérance et présente les principaux éléments à prendre en compte pour la maîtrise de l'infogérance, du point de vue des activités du client et de celles du prestataire de services.

Audit des contrôles applicatifs
Définit la notion de contrôles applicatifs et les compare aux contrôles généraux informatiques, et indique comment déterminer l'étendue des revues de contrôles applicatifs.

Gestion des identités et des accès
Couvre les principaux concepts relatifs à la gestion des identités et des accès, les risques y afférents, détaille l'audit du programme de gestion des identités et des accès et présente un exemple de liste de contrôle à l'intention des auditeurs.

La série complète peut être téléchargée sur le site Web de l'IIA : www.theiia.org/technology.

Gestion de la continuité d'activité

Auteurs

David Everest, Key Bank

Roy E. Garber, Safe Auto Insurance Co.

Michael Keating, Navigant Consulting

Brian Peterson, Chevron Corp.

Juillet 2008

Copyright © 2008 par l'Institute of Internal Auditors, 247 Maitland Avenue, Altamonte Springs, Florida 32701-4201, États-Unis. Tous droits réservés. Aucune partie de cette publication ne peut être reproduite, stockée dans un système de consultation ou transmise sous quelque forme que ce soit, ni par aucun moyen (électronique, mécanique, reprographie, enregistrement ou autre), sans l'autorisation préalable de l'éditeur.

L'IIA publie ce document à titre informatif et pédagogique. Cette publication entend donner des informations, mais ne se substitue en aucun cas à un conseil juridique ou comptable. L'IIA ne fournit pas ce type de service et ne garantit, par la publication de ce document, aucun résultat juridique ou comptable. En cas de problèmes juridiques ou comptables, il convient de recourir à l'assistance de professionnels.

Sommaire

1. RÉSUMÉ 1
2. INTRODUCTION 3
   - 2.1 Définition de la gestion de la continuité d'activité 3
   - 2.2 Planification de la gestion de crise 3
   - 2.3 Reprise des SI après sinistre 3
3. SE PRÉPARER 4
4. LES RISQUES DE L'ENTREPRISE 5
   - 4.1 Scénarios de catastrophes courantes 5
   - 4.2 Effets des catastrophes courantes 6
5. EXIGENCES RELATIVES À LA GESTION DE LA CONTINUITÉ 7
   - 5.1 Soutien par la direction 8
   - 5.2 Évaluation et réduction des risques 9
   - 5.3 Analyse d'impact 10
   - 5.4 Stratégie de reprise et de continuité d'activité 12
   - 5.5 Reprise des SI après sinistre 13
   - 5.6 Sensibilisation et formation 15
   - 5.7 Maintenance du programme de gestion de la continuité 16
   - 5.8 Entraînement à la continuité d'activité 17
   - 5.9 Communication de crise 20
   - 5.10 Coordination avec les organismes extérieurs 20
6. INTERVENTIONS D'URGENCE 22
7. GESTION DE CRISE 23
8. CONCLUSION / RÉSUMÉ 24
9. ANNEXE 25
   - 9.1 Exemple de guide d'audit 25
   - 9.2 Normes et principes directeurs portant sur la gestion de la continuité d'activité 25
   - 9.3 Modèle de maturité des dispositifs de gestion de la continuité 26

GLOSSAIRE 41

À PROPOS DES AUTEURS 42

1. Résumé

La plupart des professionnels s'accordent à penser que, pour réussir, les cadres d'entreprise passent un temps considérable à analyser le marché, à élaborer et déployer des stratégies, à définir des objectifs de performance et financiers, à établir et exécuter des plans d'exploitation, à rendre compte des résultats financiers et à communiquer avec les parties prenantes. La plupart seraient également d'accord pour dire que, avant la préparation mondiale au passage à l'an 2000, la gestion de la continuité d'activité ne constituait pas une priorité importante pour tous les cadres d'entreprises. Bien que plusieurs sinistres aient récemment fait prendre conscience des risques de non-continuité d'activité, ainsi que de leur impact sur les aspects financiers et les opérations des sociétés, il subsiste toujours des entreprises qui ne prennent pas garde aux signes avant-coureurs et qui ne se préparent pas à un sinistre ou à une interruption d'activité. Si les perturbations imputables à des facteurs humains ou à des phénomènes naturels peuvent être considérés comme imprévisibles, il est possible de gérer leurs répercussions à condition qu'un bon programme de gestion de la continuité fasse partie de la politique générale de gouvernance de l'entreprise.

La gestion de la continuité d'activité a pour finalité de permettre à une organisation de rétablir ses processus métiers critiques après la survenue d'un sinistre. Composante de la gestion des risques, face à des risques probables, la gestion de la continuité d'activité est destinée à mettre en place les dispositifs nécessaires à la poursuite des activités en fonction de leur valeur pour l'entreprise. Certaines entreprises, qu'elles soient grandes, petites ou moyennes, ne sont pas correctement préparées à des incidents susceptibles de les paralyser complètement ou partiellement pendant une longue période. Les exemples rapportés montrent comment des entités ou des secteurs entiers ont subi de graves dommages financiers parce qu'ils n'étaient pas préparés à ces aléas. Ce fut le cas, notamment, du secteur du transport aérien des États-Unis après les attaques terroristes du 11 Septembre 2001, de TfL (Transport for London) après les attentats à la bombe de Londres, et de la pêche commerciale au Sri Lanka et en Thaïlande après le tsunami de 2004. Les dommages peuvent se traduire, entre autres, par la perte de clients, un manque à gagner, une atteinte à la réputation ou la non-obtention de permis ou d'autorisations. En ne se préparant pas, ou pas suffisamment, l'entreprise s'expose à un risque dont l'ampleur dépend de chaque type d'activité.

Que ce soit en raison d'un recul conjoncturel dans un secteur, de l'absence de management éclairé ou d'autres décisions budgétaires, les défenseurs des programmes de gestion de la continuité, tels que les responsables de l'audit interne, constatent souvent que les recommandations d'amélioration qu'ils formulent à l'intention de l'encadrement ne sont pas prises en compte ou que leur application est reportée à une échéance lointaine. Il appartient au responsable de l'audit interne de signaler les carences de la gestion de la continuité à la direction et au comité d'audit ; par exemple, lorsqu'un audit ou une autre forme d'analyse révèle que la direction ne peut pas apporter d'éléments attestant que, si un sinistre se déclare, les opérations et les systèmes seront rétablis d'une manière cohérente avec les objectifs commerciaux, financiers et opérationnels de l'organisation, compte tenu des différents scénarios de survenue d'événements perturbateurs.

Ce Guide pratique d'audit des technologies de l'information (GTAG) a été rédigé en tenant compte du point de vue du responsable de l'audit interne. Ce dernier a la tâche difficile de sensibiliser les chefs d'entreprise aux risques, aux contrôles, aux coûts et aux avantages liés à l'adoption d'un programme de gestion de la continuité. Certes, de récents sinistres dans le monde ont conduit certains dirigeants à s'intéresser à ce type de programmes, mais d'autres chefs d'entreprise ne tiennent toujours pas compte du risque et / ou ne le traitent pas. La difficulté principale est donc de les amener à faire de la gestion de la continuité une priorité. À première vue, tout dirigeant pourrait affirmer que la gestion de la continuité est une bonne idée. Cependant, lorsqu'il s'agit de passer à l'action, certains peinent à trouver le

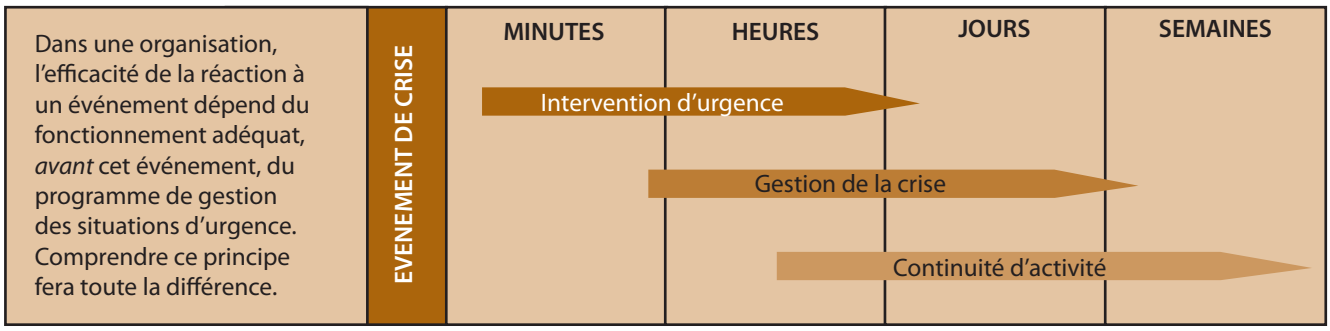


Figure 1. Programme de gestion des situations d'urgence.

budget nécessaire au financement d'un tel programme, ainsi qu'un sponsor qui aura le temps d'en assurer le succès. Le présent guide aidera le responsable de l'audit interne à informer sur le risque de non-continuité d'activité et à accompagner la direction dans l'élaboration et la tenue à jour d'un programme *ad hoc*.

Comme le montre la figure 1, le responsable de l'audit interne doit considérer la gestion de la continuité d'activité comme l'un des trois éléments d'un programme de gestion des situations d'urgence (Note : on trouvera sans doute le concept de programme de gestion des situations d'urgence dans le monde entier, utilisé dans diverses administrations publiques et entreprises, mais cela ne signifie pas pour autant qu'il s'agit d'un terme courant employé par les spécialistes). L'intervention d'urgence est l'action qui est menée immédiatement après la survenue d'une crise. Elle vise à éviter, dissuader et prévenir les sinistres, ainsi qu'à préparer l'organisation à réagir en cas de sinistre. Elle a pour but de sauver des vies, d'assurer la sécurité et de déployer les premiers efforts visant à limiter les dommages causés aux actifs. La gestion de crise, quant à elle, est axée sur la gestion de la communication externe, et interne dans certaines entreprises, et sur les activités de la direction générale lors d'un sinistre. Même dans un environnement où l'intervention d'urgence et la gestion de crise sont matures et efficaces, il arrive que la gestion de la continuité d'activité reste inadéquate. Les dispositifs de gestion de la continuité sont centrés sur la reprise des processus critiques, de façon à limiter le plus possible les conséquences pour l'entreprise, notamment financières, dans le cas d'un sinistre ou d'une interruption d'activité. La gestion de la continuité doit être en cohérence avec l'intervention d'urgence et la gestion de crise, mais devrait constituer un programme distinct.

Le responsable de l'audit interne devrait donc être à même de répondre à trois questions simples, mais fondamentales, concernant la continuité d'activité :

1. La direction de l'organisation comprend-elle bien le niveau actuel de risque de non-continuité d'activité, ainsi que l'impact potentiel de tel ou tel degré probable d'interruption des opérations ?
2. L'organisation peut-elle démontrer que les risques de non-continuité de l'activité sont ramenés à un niveau acceptable aux yeux de la direction et font périodiquement l'objet d'une nouvelle évaluation ?
3. Si le risque de non-continuité de l'activité est inacceptable mais que l'encadrement a décidé de l'assumer, les actionnaires, les partenaires commerciaux et autres acteurs sont-ils au courant de cette décision de ne pas réduire le risque ? Cette décision d'accepter le risque est-elle correctement documentée ?

Si la réponse à l'une de ces questions est « non », le présent guide peut être utile : il permettra aux responsables de l'audit interne d'appréhender de façon précise le programme, les risques et les contrôles afférents à la gestion de la continuité d'activité, et leur apportera des informations qui leur permettront d'étayer les discussions avec l'encadrement et le conseil. L'intérêt de ce guide est de présenter une synthèse de haut niveau aux cadres, dans des termes simples, et des recommandations détaillées aux auditeurs internes procédant à des évaluations. Le présent guide est axé sur la manière dont la gestion de la continuité d'activité, en tant que programme ou référentiel, est conçue pour permettre aux chefs d'entreprise de gérer le niveau de risque auquel l'organisation pourrait être confrontée s'il survenait un événement perturbateur, d'origine naturelle ou humaine, menaçant l'opérabilité au sens large. Il porte sur la planification de la reprise après sinistre, qui a trait à la continuité de l'infrastructure critique des systèmes d'information (SI) et des systèmes applicatifs de l'entreprise, étant donné que de nombreuses fonctions sont aujourd'hui, pour l'essentiel, automatisées. Le responsable de l'audit interne pourra ainsi jeter les bases d'une évaluation efficace et de la communication des informations clés aux parties prenantes.

2. Introduction

Le présent guide décrit les connaissances dont doivent disposer les membres des organes de direction, l'encadrement et les auditeurs internes pour appréhender l'efficacité des dispositifs de reprise d'activité et leur impact sur l'entreprise. D'autres professionnels peuvent également juger ce guide utile et pertinent. Ce GTAG donne des informations sur l'évaluation des dispositifs de gestion de la continuité et décrit les différentes composantes d'un programme détaillé, ainsi que la manière d'élaborer le plan correspondant à une organisation donnée.

2.1 Définition de la gestion de la continuité d'activité

La gestion de la continuité d'activité est le processus par lequel une organisation se prépare à des incidents futurs qui pourraient menacer sa mission principale et sa viabilité à long terme. Ces incidents peuvent être des événements locaux, tels que l'incendie d'un bâtiment, régionaux, par exemple un séisme, ou nationaux, comme une pandémie. Voici les principales composantes de la gestion de la continuité d'activité :

- **Soutien de la direction –** La direction doit montrer qu'elle soutient l'élaboration, le maintien et l'exécution adéquate d'un plan de continuité d'activité en y assignant des ressources, du personnel et des budgets appropriés.
- **Évaluation et réduction des risques –** Il faut identifier les risques potentiels imputables à des menaces telles qu'un incendie ou une inondation, et déterminer leur probabilité et leur impact potentiel pour l'entreprise. Ces tâches doivent se dérouler sur le site et dans les différents services de l'entreprise, afin que les risques associés à tous les événements crédibles soient appréhendés et correctement gérés.
- **Analyse d'impact –** L'analyse d'impact sert à identifier les processus de l'entreprise qui jouent un rôle clé dans la préservation du fonctionnement des unités d'affaires en cas de sinistre, et à déterminer dans quel délai ils doivent être rétablis.
- **Stratégie de reprise et de continuité d'activité –** Cette stratégie porte sur les mesures, les personnes et les ressources nécessaires au rétablissement d'un processus métier critique.
- **Sensibilisation et formation –** Pour la bonne exécution du plan, il est crucial d'informer sur le programme de gestion de la continuité d'activité et sur les plans de continuité, ainsi que d'y sensibiliser les parties concernées.
- **Tests –** Le personnel doit participer à des tests réguliers, du programme de gestion de la continuité et des plans de continuité.
- **Maintenance –** Les dispositifs de gestion de la continuité et la documentation correspondante doivent être maintenus afin de rester pertinents et en phase avec les priorités de l'entreprise.

2.2 Planification de la gestion de crise

La planification de la gestion de crise détermine la façon dont l'entité informera le grand public, son personnel et diverses parties prenantes sur une crise et sur les mesures prises pour redémarrer l'activité. La gestion de crise s'appuie sur des méthodes traitant à la fois de la réalité et de la perception des crises. Ces méthodes sont documentées dans un plan de gestion de crise. La gestion de crise recourt également à des indicateurs permettant de définir quels scénarios constituent une crise et doivent par conséquent déclencher les mécanismes d'intervention nécessaires. Elle concerne la communication pendant la phase de réaction à une situation d'urgence.

2.3 Reprise des SI après sinistre

La reprise des éléments des systèmes d'information (SI) après un sinistre passe par des opérations de rétablissement qui sont critiques pour le redémarrage de l'activité, notamment par la restauration de l'accès aux données (documents, matériels, logiciels, etc.), des communications (courrier électronique, téléphone, etc.), de l'espace de travail et d'autres processus de l'entreprise après un sinistre. Le plan de reprise après sinistre doit être bien établi, minutieusement testé et être en phase avec le plan de gestion de la continuité d'activité, afin d'accroître la probabilité de récupération réussie des documents vitaux pour l'organisation.

3. Se préparer

La préparation aux situations d'urgence n'est plus réservée aux entreprises implantées dans les régions à forte activité sismique ou menacées par des cyclones. Outre les pandémies et les catastrophes naturelles, elle doit désormais prendre en compte les catastrophes anthropiques, telles qu'un attentat. Savoir comment agir lors d'une situation d'urgence est un élément clé de la préparation et peut faire toute la différence lorsque chaque seconde compte. La préparation a pour finalité la reprise des opérations de l'entreprise avec autant de transparence que possible vis à vis des clients. Voici quelques exemples de récents événements catastrophiques qui ont affecté à la fois des grandes et des petites sociétés :

- La flambée de SRAS (syndrome respiratoire aigu sévère), de novembre 2002 à juillet 2003, s'est traduite par 8 096 cas d'infection connus et 774 décès. Cette quasi-pandémie a provoqué une forte baisse, par endroits de 90 %, de la fréquentation des restaurants chinois en Amérique du Nord. La plupart des conférences et salons programmés dans les grandes villes ont été annulés. De plus, l'intervention des pouvoirs publics a perturbé les activités habituelles (déplacements, chaîne logistique, etc.) de nombreuses entreprises situées dans les pays présentant des cas d'infection connus.
- Les attentats du 11 Septembre 2001 contre le Pentagone et le World Trade Center ont été les plus dévastateurs qu'aient subis les États-Unis depuis le bombardement de Pearl Harbor. Ils ont non seulement porté atteinte à des installations militaires, mais également touché des infrastructures civiles et des entreprises de ce pays.
- Les attentats à la bombe du 7 juillet 2005 à Londres ont consisté en une série d'explosions, planifiées par des terroristes, dans le système de transports publics de cette ville. Ces attentats, qui ont fait plus de 50 morts et 700 blessés, ont gravement perturbé les transports, ainsi que le réseau de communications mobiles du pays.
- Le cyclone Katrina (qui s'est formé le 23 août 2005) est peut-être la catastrophe naturelle la plus coûteuse de tous les temps aux États-Unis. Au moins 1 836 personnes ont péri à cause de ce cyclone et des inondations qu'il a causées. D'après les estimations, Katrina a provoqué 81,2 milliards de dollars de dégâts, notamment dans l'industrie (pétrole, raffinage et chimie, principalement), le commerce (hôtellerie et restauration, pour l'essentiel) et l'agriculture.

Depuis 1983, certaines instances de réglementation, dont l'American Bankers Association and Banking Administration Institute, imposent à leurs membres la réalisation d'exercices d'entraînement à la continuité opérationnelle (auxquels s'ajoutent ultérieurement des manuels plus formels relatifs aux plans de continuité) qui protègent les intérêts publics. Les normes plus récentes s'appuient sur des règles formalisées dans l'ISO / CEI 27002.

Il est fréquent qu'un programme de gestion de la continuité d'activité n'apparaisse pas utile tant que l'on n'en a pas besoin, peut-être parce qu'il est difficile de calculer son retour sur investissement avant qu'une catastrophe ne survienne. La direction doit comprendre que, si une telle situation se produit, l'activité doit se poursuivre mais dans des conditions très différentes. Étant donné que le coût d'un sinistre peut faire disparaître l'entreprise, les dirigeants doivent mettre en balance le coût de la préparation et celui de la cessation d'activité pendant une semaine, un mois, ou définitivement, en fonction du sinistre. Nombre de pays, à travers le monde, obligent certains secteurs à disposer d'un plan de continuité d'activité testé. Aux États-Unis, toutes les sociétés opérant dans la finance, les services d'intérêt public et la santé doivent impérativement disposer de ce type de plan et le tenir à jour. Il existe par ailleurs des règles et lignes directrices, générales ou spécifiques à un secteur, pour une bonne gestion de la continuité (annexe « Normes et lignes directrices relatives à la gestion de la continuité d'activité », page 25).

Morgan Stanley (MS) a tiré un important enseignement du premier attentat contre le World Trade Center, en 1993. Aucun membre de son personnel n'a perdu la vie lors de cette attaque, mais il a fallu quatre heures pour évacuer tous les employés travaillant sur ce site. En conséquence, la direction a décidé qu'il fallait réviser le plan de continuité d'activité. MS a ainsi examiné de près ses opérations et le risque de sinistres, et élaboré un nouveau plan. Le 11 septembre 2001, cette planification a porté ses fruits : lorsque le premier avion détourné s'est écrasé contre l'une des tours jumelles, la sécurité de MS a évacué tout le personnel. Cette fois, l'évacuation n'a pris que 45 minutes, ce qui a permis à MS de commencer à rétablir ses activités journalières. Les améliorations qui avaient été apportées aux dispositifs d'intervention d'urgence ont probablement sauvé beaucoup de vies. Les dispositifs de gestion de la continuité ont, eux aussi, été améliorés dans le cadre de cet examen.

4. Les risques de l'entreprise

Des catastrophes naturelles surviennent périodiquement dans le monde. Cyclones, inondations, séismes et incendies brisent des vies et dévastent des entreprises. Les catastrophes d'origine humaine, comme les incendies, les pannes de courant ou les actes terroristes, ne sont pas moins destructeurs. Ensemble, ces aléas induisent des risques pour l'activité normale. Parfois, les conséquences financières persistent pendant des années. Certaines entreprises ne reviennent jamais à la situation antérieure, d'autres ne s'en remettent tout simplement pas et disparaissent. On peut toutefois éviter une telle issue dans la quasi-totalité des cas.

Presque toutes les régions du globe comportent une zone sujette aux cyclones, aux tempêtes, aux séismes, aux feux de friche et / ou aux inondations. Le feu peut ravager un bâtiment dans n'importe quelle ville de n'importe quel état. De même, le terrorisme peut frapper partout sur la planète.

4.1 Scénarios de catastrophes courantes

Les catastrophes courantes dans le monde sont les suivantes :

Un **incendie** peut se déclarer dans un immeuble de bureaux, dans un complexe, dans une installation industrielle ou dans toute une zone proche d'une forêt ou de bois. Chaque année, aux États-Unis, plus de 4 000 personnes perdent la vie et plus de 20 000 sont blessées lors d'incendies dont bon nombre auraient pu être évités. On estime que les incendies causent 10 milliards de dollars de dégâts annuels directs aux biens (rien que dans ce pays), et ce chiffre n'englobe pas les pertes financières subies par les entreprises dont les opérations sont perturbées.

Une **pandémie** est la flambée d'une maladie à l'échelle mondiale. Une pandémie de grippe se produit quand apparaît un nouveau virus de la grippe A contre lequel les êtres humains sont peu ou non immunisés. Ce virus commence alors à provoquer une grave maladie et se propage facilement d'une personne à l'autre. Beaucoup de pays ont commencé à se préparer à une pandémie. Ils ont identifié leurs secteurs d'infrastructure critiques, tels que la finance, la banque, l'énergie, les transports et l'administration publique. Ces secteurs doivent élaborer des plans de continuité d'activité visant à préserver les fonctions critiques des entreprises durant une pandémie. Une pandémie peut avoir un impact économique dévastateur, car elle rendrait indisponible le personnel, ce qui est susceptible de déboucher sur l'interruption des activités de l'entreprise. Si une pandémie survient, elle sera probablement de longue durée et générale, et pourrait nécessiter des changements temporaires dans de nombreux pans de la société : écoles, bureaux, transports et autres services publics, notamment. Une population informée et préparée peut agir de façon appropriée pour réduire ses risques durant une pandémie.

Le **terrorisme** est l'usage de la force ou de la violence à l'encontre de personnes ou de biens, en violation du droit pénal des pays, à des fins d'intimidation, de coercition ou d'obtention d'une rançon. Les terroristes recourent souvent à des menaces afin de :

- Créer un climat de peur dans la population.
- Convaincre le grand public que l'État est impuissant à prévenir le terrorisme.
- Médiatiser une cause.

Font partie des actes de terrorisme les menaces terroristes, assassinats, enlèvements, détournements, alertes et attentats à la bombe, cyber-attaques (attaques informatiques) et l'utilisation d'armes chimiques, biologiques, nucléaires ou radiologiques. Les actes de terrorisme dévastent de vastes agglomérations, dans lesquelles ils désorganisent les entreprises, et ont de graves conséquences sur les effectifs des entreprises de la région touchée.

Une **attaque biologique** consiste à répandre délibérément des germes ou d'autres substances biologiques qui peuvent provoquer une maladie chez les gens. Pour avoir un effet, de nombreux agents doivent être inhalés, pénétrer par une coupure cutanée ou être ingérés. Certains agents biologiques, tels que l'anthrax, ne causent pas de maladie contagieuse. D'autres, comme le virus de la variole, peuvent engendrer des maladies transmissibles d'une personne à l'autre par contact, par la toux, etc. Une **attaque chimique** est l'émission délibérée d'un produit toxique, sous forme gazeuse, liquide ou solide, qui peut empoisonner les êtres humains et l'environnement. La menace d'attaque biologique peut avoir un impact dévastateur sur une entreprise (évacuation des locaux, par exemple) même en l'absence d'attaque réelle.

Les **tornades** sont les tempêtes les plus violentes que génère la nature. Elles peuvent survenir sans signe annonciateur et être invisibles jusqu'à ce que des poussières et des débris s'envolent ou qu'un nuage caractéristique, en entonnoir, apparaisse. Bien que plus fréquentes dans certaines régions du monde, elles peuvent se produire n'importe où et en toute saison. Il est donc particulièrement important de s'y préparer. Elles peuvent endommager les installations des entreprises et entraîner une indisponibilité du personnel.

Les **cyclones**, typhons et ouragans sont des tempêtes tropicales majeures qui se forment dans les eaux tropicales ou subtropicales du globe. Les scientifiques savent désormais les prévoir en grande partie. Les organisations situées dans ou près des zones côtières touchées par des cyclones, des typhons ou des ouragans doivent disposer d'un plan d'évacuation. L'évacuation elle-même peut nettement perturber leurs activités.

Accroissement des coûts des catastrophes naturelles						
Bien que les catastrophes naturelles aient de tout temps prélevé leur tribut, tout porte à croire que leur fréquence et leur intensité augmentent depuis quelques décennies et que cette tendance ne va pas s'interrompre. Cette évolution s'explique notamment par l'essor de l'urbanisation qui aboutit à une concentration accrue de la population dans des zones vulnérables (Freeman, Keen et Mani, 2003). Elle reflète aussi les changements climatiques, en particulier ceux associés à l'élévation des températures à la surface du globe, qui semblent accentuer la fréquence et l'intensité des événements météorologiques délétères, par exemple les cyclones, inondations et sécheresses (GIEC, 2007). Étant donné que des catastrophes naturelles plus fréquentes et plus intenses affectent des zones de plus en plus densément peuplées, leurs coûts s'accroissent nettement au fil du temps (voir *infra*).						
	1950-59	1960-69	1970-79	1980-89	1990-99	2000-2005
Nombre d'événements	21	27	47	63	91	57
(en milliards de dollars, à prix constants de 2005)						
Pertes globales	48.1	87.5	151.7	247.0	728.8	575.2
Perte moyenne	2.3	3.2	3.2	3.9	8.0	10.1

Figure 2. Accroissement des coûts des catastrophes naturelles[1].

Les **inondations** constituent un type de catastrophe naturelle courant dans de nombreuses régions du monde. Cependant, elles ne se ressemblent pas toutes. Certaines peuvent s'amorcer lentement pendant un long épisode pluvieux ou lorsqu'un redoux fait suite à de fortes chutes de neige. D'autres, telles que les crues subites, peuvent se déclencher rapidement, y compris sans signe de pluie visible. La plupart des régions du monde doivent être préparées aux inondations, mais surtout celles situées dans des zones de faible altitude, près d'une étendue d'eau ou d'un cours d'eau, ou en aval d'un barrage. Même un très petit ruisseau ou le lit d'un cours d'eau à sec peut déborder et causer une inondation. Celle-ci peut perturber la disponibilité du personnel d'une entreprise, y compris si le site principal de celle-ci ne subit pas d'impact direct.

4.2 Effets des catastrophes courantes

Différentes catastrophes courantes peuvent se traduire par des pertes :

- de **personnes.** Dans le cas d'importantes pertes de vies humaines ou d'indisponibilité de leur personnel, les organisations ne disposent pas des effectifs leur permettant de fonctionner au jour le jour.
- d'**installations** et d'**équipements.** Plusieurs des catastrophes décrites plus haut peuvent détruire ou gravement endommager les installations d'exploitation, les usines, les bureaux et autres sites critiques d'une entreprise.
- d'**infrastructures de communication.** Il arrive qu'une organisation ne soit pas en mesure de communiquer avec son personnel, ses fournisseurs et ses clients.
- d'**approvisionnements**, tels que l'alimentation électrique, les fournitures, les matières premières destinées à la production...
- d'**informations** et de SI. Les applications critiques de l'entreprise peuvent ne pas fonctionner correctement.

[1] David Hoffman, "Innovations in insurance can help countries manage the fiscal impact of natural disasters", revue *Finance & Development*, mars 2007, vol. 44, n° 1.

5. Exigences relatives à la gestion de la continuité

La figure 3 présente les actions nécessaires pour satisfaire les exigences relatives à la gestion de la continuité d'activité.

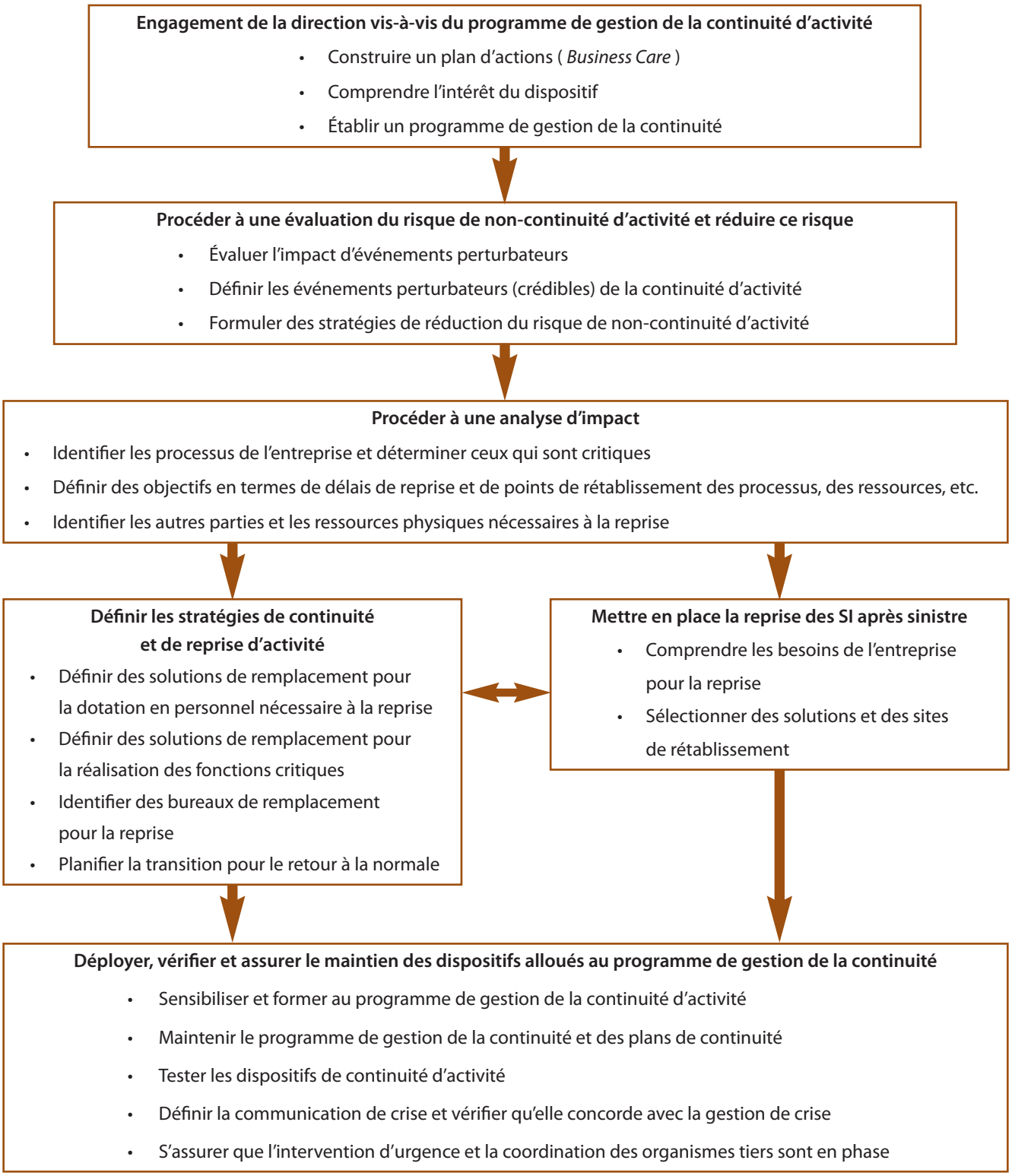


Figure 3. Diagramme de flux correspondant aux exigences relatives à la gestion de la continuité d'activité.

5.1 Soutien par la direction

Dans toute organisation, le soutien apporté par la direction est indispensable au succès de la continuité d'activité. La direction générale doit veiller à l'instauration de politiques imposant aux équipes de management, dans toute l'organisation, le déploiement d'un programme de gestion de la continuité d'activité pour leurs unités d'affaires. Toutes les politiques de gestion des situations d'urgence doivent être harmonisées, afin que la gestion de crise, l'intervention d'urgence et la gestion de la continuité fonctionnent ensemble lors d'un sinistre.

A. Soutien de la direction générale

La direction générale doit montrer clairement qu'elle soutient la gestion de la continuité d'activité et le programme de gestion des situations d'urgence. Elle peut y parvenir de diverses manières, notamment :

- En établissant, au sein de l'organisation, une cellule centrale de gestion de la continuité et de gestion de la gouvernance (définition de la standardisation nécessaire, par exemple), du partage du savoir, de la coordination des bonnes pratiques, du conseil et de la gestion de la continuité d'activité entre les unités d'affaires.
- En créant un système de gestion de la continuité d'activité que chaque entité opérationnelle devra déployer.
- En veillant au financement approprié des opérations de gestion de la continuité d'activité, à l'échelle de l'organisation, via le plan d'entreprise (*business plan*) annuel et les tests, et en s'assurant que les unités d'affaires peuvent financer leurs efforts de gestion de la continuité.
- En communiquant sur l'importance de la gestion de la continuité et comment elle rehausse la valeur de l'entreprise.
- En participant à des exercices d'entraînement à la continuité d'activité, à des sessions de formation et à d'autres programmes de gestion des situations d'urgence.

Le système de gestion de la continuité d'activité que chaque unité d'affaires doit déployer comportera :

- Une définition de la gestion de la continuité et de son importance dans l'entreprise.
- Une description des étapes nécessaires pour déployer et maintenir un programme de gestion de la continuité au sein d'une unité d'affaires.
- La désignation des responsables de la gestion de la continuité par chaque unité d'affaires (voir *infra* « Soutien de la direction à l'unité d'affaires »).
- La définition des indicateurs de gestion de la continuité, qui peuvent servir à évaluer les avancées du programme au niveau de l'organisation, de l'unité d'affaires ou de la région (par exemple, chaque unité d'affaires établit ses propres indicateurs locaux).
- Le déploiement d'un programme qualité continu portant sur la gestion de la continuité d'activité et pouvant être révisé par chaque unité d'affaires dans le cadre du déploiement et de la tenue à jour de la gestion de la continuité.

B. Soutien de la direction à l'unité d'affaires

La direction de l'unité d'affaires ou la direction régionale doit, elle aussi, montrer clairement qu'elle soutient la gestion de la continuité d'activité et le programme de gestion des situations d'urgence. Elle peut y parvenir de diverses manières, notamment :

- En déployant le système de gestion de la continuité défini par l'organisation.
- En veillant à ce que toutes les équipes, au sein de l'unité d'affaires, participent à l'effort de gestion de la continuité, afin qu'elles mettent en place des dispositifs de continuité en adéquation avec leurs risques et leur valeur pour l'entreprise.
- En désignant la personne qui prendra part à la gouvernance de la gestion de la continuité à l'échelle de l'organisation (définition de la standardisation nécessaire, par exemple), au partage du savoir, à la coordination des bonnes pratiques, aux activités de conseil et à la gestion de la continuité entre unités d'affaires.
- En communiquant sur l'importance de la gestion de la continuité et comment elle rehausse la valeur de l'entreprise.
- En participant à des exercices d'entraînement à la continuité d'activité, à des sessions de formation et à d'autres programmes de gestion des situations d'urgence pour l'unité d'affaires concernée.
- En veillant au financement approprié des activités de gestion de la continuité d'activité de l'unité d'affaires, via le plan d'entreprise annuel de ces dernières.

Lors du déploiement du système de gestion de la continuité, la direction de l'unité d'affaires ou la direction régionale doit :

- Actualiser la section du plan consacrée à la définition de la gestion de la continuité, afin de déterminer la valeur que revêt l'unité d'affaires pour l'entreprise.
- Comprendre les mesures nécessaires pour déployer un programme de gestion de la continuité au sein d'une unité d'affaires et pour assurer le maintien de ce programme.
- Désigner les responsables de la gestion de la continuité au sein de l'unité d'affaires, notamment en assignant des personnes à des postes clés, tels que celui

de sponsor de la gestion de la continuité de l'unité d'affaires (financement et orientation), de responsable de la gestion de la continuité (conduite et maintenance des dispositifs de gestion de la continuité) et de coordinateur de la gestion de la continuité (organisation des activités y afférentes, d'après les instructions du responsable de la gestion de la continuité).
- Définir les indicateurs de gestion de la continuité de l'unité d'affaires, qui peuvent servir à évaluer les avancées du programme.
- Déployer un programme qualité continu portant sur la gestion de la continuité de l'unité d'affaires.

5.2 Évaluation et réduction des risques

La direction de l'unité d'affaires ou la direction régionale doit évaluer les risques de non-continuité d'activité pour chacune de ses fonctions et chacun des sites concernés (ville ou région). Cet exercice a pour objectif d'identifier les risques probables susceptibles de perturber les processus critiques de l'entreprise mis en œuvre sur certains sites d'opération. L'évaluation des risques de non-continuité d'activité sert à définir le périmètre du programme global de gestion de la continuité en dressant une liste d'événements probables et de leurs conséquences à traiter dans un plan de réduction des risques (prévention, par exemple) et dans le programme de gestion de la continuité. Il est impossible de prévoir tous les risques ou de réduire tous les risques connus qu'il peut être nécessaire d'accepter. Parmi les participants à l'évaluation des risques de non-continuité d'activité doivent figurer, notamment, des membres du personnel de l'entreprise, ainsi que de l'entité chargée de l'hygiène, de la sécurité et de l'environnement, de la direction technique, du service juridique, des ressources humaines et du personnel médical.

Quelques événements perturbateurs sont *fortement susceptibles* de se produire, comme les cyclones et / ou le dysfonctionnement de services d'intérêt public dans certaines parties du monde, ou d'autres événements survenant périodiquement. Des plans tactiques spécifiques de continuité d'activité peuvent être nécessaires pour ces événements prévisibles. La plupart des événements ont une faible probabilité de survenue, notamment les séismes. Un séisme peut se produire dans certaines régions, mais il est susceptible de toucher une autre partie de la zone. Par conséquent, si le site des opérations se trouve dans une zone sismique, cette situation doit être considérée comme un événement perturbateur probable, ce que l'on appelle souvent un événement *crédible*.

Aucune entreprise ne peut éradiquer tous les risques d'un environnement et rester efficace dans la conduite de ses activités. Il faut donc procéder à un arbitrage, qui est la clé de la gestion des risques de non-continuité d'activité. Lors de l'évaluation des événements perturbateurs, il importe d'identifier ceux qui sont crédibles et de rechercher tous les événements potentiels qui peuvent avoir un impact sur les opérations de l'entreprise. Les méthodes envisageables pour prévoir des événements perturbateurs consistent notamment à :
- Examiner les données historiques portant sur des organisations analogues implantées dans la même région.
- Exploiter les chiffres des pouvoirs publics ou du secteur concernant les risques potentiels.
- Recourir à des spécialistes lorsque le modèle d'entreprise change ou s'il existe peu de données disponibles pour une évaluation détaillée des risques.

A. Exemples d'événements perturbateurs

Voici quelques exemples d'événements perturbateurs susceptibles d'affecter les processus de l'entreprise :
- Catastrophes naturelles : séisme, cyclone, pluies / inondations, foudre…
- Catastrophes industrielles : incendie, explosion, déversement d'un produit, contamination…
- Défaillances dues à un fournisseur : dysfonctionnements du fournisseur de composants, des fournisseurs d'énergie…
- Autres catastrophes : crash aérien…
- Épidémie : pandémie, autres risques sanitaires.
- Désorganisation du travail : grève, perturbations dans les transports, troubles civils…
- Instabilité économique ou politique : actes de terrorisme, attentats à la bombe, guerre…
- Facteurs humains : erreurs de membres du personnel, délits graves, fraude…
- Risques pour les SI : cyber-terrorisme, virus, intrusions informatiques, déni de service résultant d'un piratage…
- Risques pour la production et la fabrication :
  - Dysfonctionnements chez un fournisseur, concernant notamment l'alimentation électrique, les matières premières ou les services critiques.
  - Pannes de l'équipement de production au niveau de conduites, chaudières, bandes transporteuses….
  - Indisponibilité des services d'utilité publique de soutien, tels que les usines de traitement et l'équipement d'évacuation de déchets.
  - Défaillances du stockage, du transport ou de la distribution de produits.
  - Indisponibilité des processus de laboratoire, de tests et / ou de contrôles qualités critiques.
  - Défaillances des systèmes d'automatisation des processus (SI, tels que SCADA (Supervisory Control And Data Acquisition) et DCS (distribu-

ted control system), ce qui provoque l'arrêt de la production.
  - Retards dans la délivrance de permis, les formalités douanières, l'obtention de visas pour le personnel et / ou la certification par les autorités.

B. Évaluer l'impact des événements perturbateurs

Après l'identification des événements susceptibles d'avoir un impact sur chacun des sites ou dans chacune des régions où opère l'organisation, des efforts supplémentaires sont nécessaires pour comprendre ces événements. Il faut en effet évaluer certains des facteurs en jeu, afin de mieux appréhender l'étendue et l'impact d'un événement potentiel. Par exemple :

- **La portée géographique de l'impact :** un bâtiment (incendie, par exemple), tout un complexe (déversement de produits chimiques), une zone métropolitaine (grève des transports), une grande région (séisme) ou le monde entier (pandémie grippale).
- **La durée de l'impact :** Nombre de jours avant que les opérations ne soient probablement rétablies à 75 %, soit 75 % du personnel, des ressources et de la production à nouveau disponibles. La durée de l'impact peut correspondre au délai nécessaire à l'organisation pour remplacer ses ressources perdues, par exemple, après un incendie, en louant un nouveau bâtiment et en le réhabilitant.
- **Disponibilité du personnel (en jours) :** Proportion du personnel susceptible de pouvoir travailler, pour chaque scénario d'événement catastrophique (en 0, 3, 7, 14 ou 30 jours). Dans le cas de certaines catastrophes, comme un séisme endommageant les habitations, il se peut que le personnel doive retourner chez lui pour une longue période.
- **Disponibilité des opérations et / ou des bureaux :** Pourcentage probable des opérations et / ou des espaces de bureaux fonctionnels (pendant les jours d'impact).
- **Disponibilité des SI (pendant les jours d'impact) :** Disponibilité probable des éléments clés des SI, pour chaque scénario d'événement catastrophique. Il s'agit de l'infrastructure des SI (dispositifs de connexion), du réseau des SI, des applications des SI, etc.

L'évaluation du risque de non-continuité d'activité peut servir à déterminer l'impact sur les processus critiques de l'entreprise. Certaines installations, telles que les bureaux de recherche et développement, peuvent comporter peu de processus critiques exécutés *in situ*. L'évaluation du risque de non-continuité sur tous les sites doit se concentrer, au minimum, sur les conséquences potentielles pour la santé et la sécurité du personnel, ainsi que pour la sûreté et l'environnement, afin que les fonctions de gestion de crise et d'intervention d'urgence disposent des ressources nécessaires pour être efficaces.

C. Élaborer des stratégies de réduction des risques

L'élaboration et le déploiement de stratégies de réduction des risques contribueront à limiter le plus possible l'impact des événements perturbateurs et amélioreront les dispositifs d'intervention. Voici des exemples de risques et les stratégies de réduction correspondantes :

- **Risques pour la sécurité lors de différentes catastrophes :** Intervention d'urgence et / ou mobilisation de l'équipe chargée de l'hygiène, de la sécurité et de l'environnement et / ou déploiement des plans opérationnels.
- **Défaillances opérationnelles :** Mise en œuvre des procédures d'exploitation standard et des activités de maintenance normales.
- **Perte du bureau principal :** Organisation du transfert des membres du personnel vers un autre bureau ou leur permettre de travailler chez eux, à condition que leur domicile soit fonctionnel (c'est-à-dire, dans le cas d'un événement régional, que leur domicile ne soit pas endommagé et qu'il dispose des ressources nécessaires, tels qu'un ordinateur, une connexion réseau, etc.)
- **Perte de connectivité du réseau informatique :** Établissement de plans de rétablissement des SI et de l'information (reprise après sinistre), afin de créer un réseau redondant ou de permettre le redémarrage.
- **Perte du centre de ressources informatiques :** Concevoir un plan permettant l'exécution manuelle des processus jusqu'à ce que les SI puissent être rétablis. Élaborer également des plans de reprise des SI après sinistre, afin de rétablir des SI sur un site de remplacement.
- Le sponsor de la gestion de la continuité et une équipe appropriée de responsables doivent examiner et valider l'évaluation des risques de non-continuité d'activité et les stratégies de réduction de ces risques. La direction devant agir pour traiter les risques, il est impératif qu'elle approuve cette évaluation et veille à ce que le plan de réduction des risques de non-continuité soit financé, appliqué et testé périodiquement.

5.3 Analyse d'impact

Une analyse d'impact vise à identifier les processus critiques de l'entreprise qui doivent être rétablis après une catastrophe. Elle peut comporter un premier examen des solutions permettant le redémarrage des processus critiques (voir « Stratégie de reprise et de continuité d'actvité » page

12). Parmi les participants à l'analyse d'impact doivent figurer des membres du personnel de l'entreprise ainsi que des fournisseurs principaux.

L'analyse d'impact doit se fonder sur les informations qui émanent de l'évaluation des risques de non-continuité, laquelle a défini les événements crédibles susceptibles de perturber le fonctionnement de l'entreprise. En général, des réunions d'analyse d'impact sont organisées séparément pour chaque équipe. Ensuite, des discussions s'engagent avec les autres équipes identifiées comme étant des acteurs essentiels après chaque réunion d'analyse d'impact.

A. Identifier les processus de l'entreprise

La première phase d'une analyse d'impact métier consiste à identifier les processus de l'entreprise exécutés par l'équipe fonctionnelle, les ressources et le personnel clé nécessaires à l'activité. Pour commencer, les processus ne doivent pas être subdivisés en un trop grand nombre de sous-processus individuels. Il convient d'identifier séparément les processus lorsque différents salariés (rôles du personnel), prestataires de services (tiers, sous-traitant, etc.) ou ressources (SI, par exemple) leurs sont affectés.

B. Déterminer le RTO et le RPO d'après l'impact sur l'entreprise

La deuxième phase d'une analyse d'impact métier consiste à identifier le type d'impact subi par l'entreprise si tel ou tel processus ne peut pas être accompli. Voici des exemples d'impact sur l'entreprise :

- Impact sur la santé et la sécurité (blessures…).
- Impact sur l'environnement (déversement d'un produit…).
- Impact sur le service client (perte de clients…).
- Impact financier (sanctions…).
- Impact sur la réglementation / le cadre juridique (action juridique lancée par les pouvoirs publics…).
- Réputation (atteinte à l'image…).

Il faut ensuite fixer un délai de reprise ou durée maximale d'interruption admissible (DMIA) (*recovery time objective* – RTO) en fonction du type d'impact sur l'entreprise. La DMIA dépend à la fois du délai au cours duquel le processus doit être rétabli et du niveau de service à restaurer (après un sinistre) afin d'éviter les conséquences inacceptables d'une non-continuité de l'activité. La DMIA est habituellement définie au moyen de marqueurs temporels standardisés, de 0, 3, 7, 14 ou 30 jours. C'est *in fine* la direction de l'entreprise qui détermine la DMIA correcte pour chaque processus. Habituellement, le coût de la solution de rétablissement augmente à mesure que la DMIA diminue (c'est-à-dire que, si le processus doit être rétabli immédiatement, le coût pourrait être élevé).

L'étape suivante est la définition d'un volume maximum de données que l'on peut accepter de perdre (DPMA : délai de perte maximum acceptable) (*recovery point objective* – RPO) si un sinistre détruit les systèmes d'information. Le personnel de l'entreprise doit déterminer combien de jours de données peuvent raisonnablement être perdus et reconstitués manuellement. Il est souvent possible de reconstituer des données à partir d'autres sources, telles que des systèmes externes qui échangent des données avec le système de l'organisation (systèmes bancaires, par exemple). C'est *in fine* la direction de l'entreprise qui détermine le DPMA correct pour chaque processus. Habituellement, le coût de la solution de reprise augmente à mesure que le DPMA diminue (c'est-à-dire que, si le processus concerné ne peut pas se permettre de perdre des données, le coût de réplication des données pourrait être très élevé).

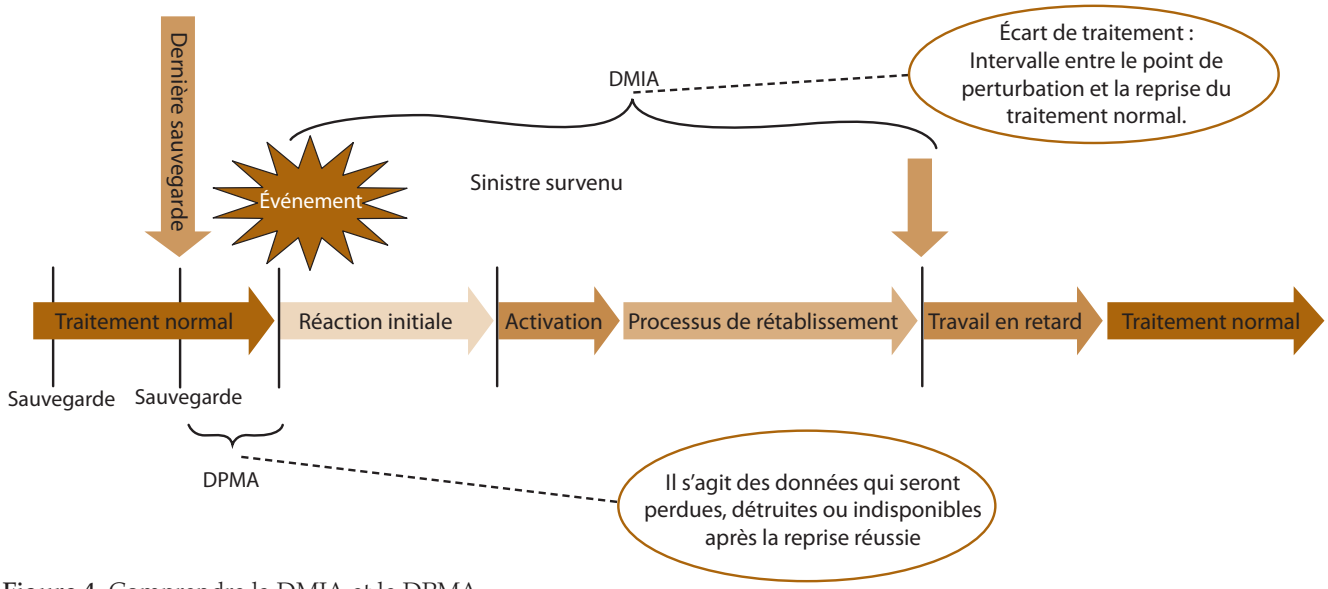


Figure 4. Comprendre la DMIA et le DPMA.

C. Identifier les autres intervenants et ressources physiques

La troisième phase de l'analyse d'impact métier (BIA : bilan d'impact sur activité) consiste à identifier les autres intervenants et ressources physiques qui sont critiques pour le processus concerné : autres départements de l'entreprise, fournisseurs, tiers, équipements essentiels et documents physiques. Il peut être nécessaire de procéder à une analyse d'impact avec d'autres intervenants qui soutiennent des processus critiques de l'entreprise, afin de s'assurer qu'ils soient préparés à aider à la reprise d'activité.

D. Faire valider l'analyse d'impact par le sponsor de la gestion de la continuité et par les responsables des équipes

Le sponsor de la gestion de la continuité et le responsable de chaque équipe doivent examiner et valider l'analyse d'impact pour le champ des opérations les concernant. Ces responsables devant veiller à la mise en œuvre des solutions de continuité et de reprise d'activité dans toute l'organisation, ils doivent répondre de l'analyse d'impact (BIA) pour leur équipe.

5.4 Stratégie de reprise et de continuité d'activité

Il faut élaborer des stratégies de reprise et de continuité d'activité pour les processus critiques de l'entreprise identifiés dans l'analyse d'impact. Cette dernière peut comporter un examen initial des solutions de rétablissement nécessaires au redémarrage des processus critiques (voir « Analyse d'impact » page 10). Des membres du personnel de l'entreprise, les principaux fournisseurs et les organisations proposant des systèmes d'information peuvent participer à la réunion portant sur la stratégie de reprise et de continuité d'activité.

Les stratégies de reprise et de continuité d'activité peuvent inclure certains des types de solutions suivants :

- **Processus manuels :** Le travail peut être accompli manuellement quand les SI sont en panne.
- **Externalisation :** Une partie du travail peut être effectuée par des entreprises tierces, des concurrents (accord réciproque) ou des fournisseurs de second rang.
- **Reprise des SI après sinistre :** Une solution de reprise des SI sera nécessaire pour les systèmes critiques, mais, ceux-ci étant parfois très coûteux, on peut dans un premier temps, après la survenue d'un sinistre, recourir à des processus manuels.
- **Redéploiement de personnel :** Identifier d'autres membres du personnel qui peuvent effectuer telle ou telle tâche.
- **Installations de remplacement :** Identifier des installations de remplacement où le personnel principal peut travailler.

Lors de l'élaboration des stratégies de reprise et de continuité, il faut prendre en compte les événements crédibles identifiés pendant l'évaluation du risque de non-continuité d'activité, ainsi que leurs effets probables sur les ressources. Le choix des installations où il est possible de transférer l'activité peut se révéler très restreint dans le cas d'une catastrophe régionale telle qu'un cyclone, ce qui peut avoir un impact au même moment sur les installations de l'entreprise et sur le domicile des membres du personnel.

A. Affecter du personnel aux opérations de reprise

Étant donné qu'une faible dotation en personnel est une résultante probable de la plupart des événements crédibles, la continuité d'activité impose toujours un redéploiement du personnel. À cette fin, la meilleure option consiste à identifier des membres du personnel qui se trouvent à l'extérieur de la zone d'impact probable des événements crédibles. S'il n'y en a pas, il faut envisager d'accroître les effectifs dans la région principale. Dans l'hypothèse où 80 % des effectifs ne seront pas disponibles si une catastrophe se produit, il convient de déterminer combien de personnes sont nécessaires pour effectuer telle ou telle tâche, et de multiplier ce nombre par cinq :

- Si une personne est nécessaire pour accomplir le travail, il faut identifier cinq personnes susceptibles de le faire.
- Si deux personnes sont nécessaires pour accomplir le travail, il faut identifier dix personnes susceptibles de le faire, et ainsi de suite.

Il se peut que ceux qui effectuent habituellement le travail connaissent d'autres méthodes permettant d'exécuter les processus critiques de l'entreprise. On peut, par exemple, exécuter manuellement les tâches, solution parfois utilisée périodiquement lorsque des systèmes sont en panne, ou faire appel au personnel d'un autre site si le personnel du site principal n'est pas disponible. Au besoin, certaines fonctions pourront être externalisées.

B. Différents modes d'externalisation de fonctions critiques

Il faut envisager diverses options permettant de faire effectuer le travail par un prestataire extérieur. Il convient aussi d'évaluer le degré de cohérence et de qualité requis pour chaque fonction critique. Si une catastrophe survient, il se peut que l'organisation soit à même de fonctionner avec des produits et services standard qui ne correspondent pas à

ses propres spécifications. Une autre option est l'externalisation à d'autres fournisseurs. En effet, beaucoup de fonctions peuvent être confiées à l'extérieur, à différentes entreprises qui fournissent des services standard. Enfin, il faut envisager de passer un accord réciproque avec des concurrents si les coûts d'investissement sont élevés ou si de nombreuses entreprises exécutent régulièrement des fonctions régulées.

Bien des risques identifiés au cours de l'analyse d'impact ont trait aux fournisseurs de produits et de services critiques pour la chaîne logistique globale de l'organisation. Ces fournisseurs peuvent apporter des matières premières essentielles ou des éléments entrant dans la fabrication de produits ou servant au conditionnement, au stockage ou à la distribution de produits. Les modalités contractuelles peuvent permettre d'être sûr que les principaux fournisseurs honorent leurs obligations, à supposer qu'ils restent eux-mêmes en activité. D'autres fournisseurs (principe de la diversité des fournisseurs) peuvent être nécessaires si le principal fournisseur est défaillant.

Une autre option consiste à déterminer le mode de fourniture des produits s'il n'y a plus du tout de production. Lors d'un sinistre, on peut envisager d'acheter un produit à des concurrents, mais passer d'avance un accord réciproque peut éviter une escalade des coûts. On peut aussi définir une hiérarchie des clients à servir, tout d'abord d'après les engagements contractuels, ensuite sur la base des futures opportunités d'affaires, etc. Identifier à l'avance des modes de production de remplacement permet de maximiser la production globale de l'entreprise dans différents scénarios de catastrophes. Les aspects à prendre en compte sont l'utilisation des ressources, la production de produits dérivés et les autres facteurs susceptibles d'optimiser la production en fonction des ressources et des services disponibles (fournisseurs et services d'intérêt public).

C. Bureaux de remplacement nécessaires aux opérations de reprise

Il peut être nécessaire de trouver des bureaux de remplacement dans la quasi-totalité des cas de sinistre imposant l'activation du plan de continuité d'activité. Nombre d'options sont envisageables pour mettre des bureaux à la disposition du personnel, mais leur coût varie fortement. En voici quelques exemples :

- Des installations d'une autre organisation situées à l'extérieur de la zone sinistrée mais à proximité du bureau principal constituent souvent une solution peu onéreuse. L'unité d'affaires concernée doit alors se référer au programme de continuité d'activité pour renvoyer à leur domicile le personnel non critique.
- Aujourd'hui, beaucoup de collaborateurs utilisent un accès à distance, depuis leur domicile ou un hôtel, pour réaliser des tâches professionnelles. Il est alors impératif qu'ils disposent des outils de sécurité (jeton d'accès à distance) et du matériel informatique (ordinateur portatif ou individuel) appropriés au télétravail. L'évaluation des solutions d'accès à distance doit prendre en compte leur impact sur la productivité, surtout compte tenu du manque de collaboration et de communication lorsqu'une équipe est disséminée sur plusieurs sites.
- Les sites de secours proposés par des prestataires de services offrent également des espaces de bureaux, mais généralement pour un coût élevé et souvent avec peu de connexions réseau pour les SI de l'organisation sinistrée.

Toute solution proposant des bureaux de remplacement doit être testée par les utilisateurs, qui doivent s'assurer qu'ils peuvent se connecter. Il faut aussi vérifier le volume disponible (test de performance) pour avoir la certitude que les locaux de remplacement pourront accueillir le nombre d'utilisateurs souhaité. Il convient de demander au personnel non critique de ne pas se connecter pendant un sinistre, afin que les ressources restent disponibles pour les personnes considérées comme clés.

D. Planifier la transition pour le retour à la normale

Il faut élaborer un plan de transition pour le retour à la normale lorsque l'organisation n'a plus besoin de recourir à des solutions de rétablissement. Ce peut être difficile, car elle opère dans des conditions anormales pendant un sinistre. Les données collectées manuellement doivent être saisies dans les systèmes quand ceux-ci sont rétablis. L'entreprise doit régulariser les mesures financières et réglementaires qu'elle avait prises pour faire face au sinistre : elle doit accomplir les formalités administratives requises et obtenir les autorisations nécessaires. Les produits échangés (empruntés) au cours du sinistre doivent être soit réapprovisionnés soit payés à la partie qui les a fournis.

Le sponsor de la gestion de la continuité et une équipe adéquate de responsables doivent valider les stratégies de continuité pour le champ des opérations les concernant. Ces responsables devant veiller à la mise en œuvre des solutions de continuité et de reprise d'activité dans toute l'organisation, ils doivent répondre des stratégies de continuité pour leur équipe.

5.5 Reprise des SI après sinistre

Suivant les fonctions exécutées et leur degré d'utilisation des SI, on peut restaurer une partie des processus critiques sans avoir besoin des SI ou des informations qui s'y rapportent. Dans d'autres cas, les SI et les informations sont nécessaires pour permettre le rétablissement de certains processus

critiques. Chaque organisation doit déterminer pendant combien de temps (en heures, jours, semaines ou davantage) les SI peuvent être indisponibles sans que cela devienne un problème mettant en péril l'ensemble de l'organisation.

Le plan de secours informatique (PSI) ou DRP (*Disater recovery planning*) est un terme utilisé pour décrire le rétablissement des SI. Certaines entreprises emploient différents termes pour englober la restauration des SI, des données, des systèmes / processus de gestion de l'information et des autres systèmes connexes. Le plan de reprise après sinistre doit décrire les stratégies de rétablissement des SI et des systèmes de gestion de l'information. Il doit comporter des instructions détaillées, notamment des renvois aux procédures, les coordonnées des fournisseurs, les diagrammes présentant les systèmes, ainsi que d'autres documents ayant trait à la reprise. Il faut actualiser les procédures de reprise détaillées lorsque les processus des systèmes et de l'entreprise évoluent.

Voici quelques exemples d'éléments à rétablir dans le cadre du plan de reprise d'activité (PRA) :

- SI, dont :
  - Centre de ressources informatiques.
  - Applications et données nécessaires à l'organisation.
  - Serveurs et autres matériels informatiques.
  - Moyens de communication, tels que le téléphone, la radio, etc.
  - Réseau, en particulier les connexions externes (avec les tiers).
  - Infrastructure des SI (services de connexion, répartition des logiciels…).
  - Services d'accès à distance.
  - Systèmes de contrôle de processus (SCADA / DCS, notamment).
- Systèmes de gestion de l'information, dont :
  - Espaces fichiers.
  - Systèmes de gestion de documents (électroniques et manuels).

A. Aspects à prendre en compte lors de la sélection des stratégies de plan de secours informatique (PSI)

- La sélection des stratégies de reprise après sinistre doit prendre en compte plusieurs aspects :
  - Le PSI doit décrire les stratégies de rétablissement des systèmes et des informations d'après les orientations émanant du personnel après qu'une partie de celui-ci a effectué une analyse d'impact.
  - Il faut évaluer les dispositifs de reprise des prestataires de technologies critiques et des informations concernées, afin de s'assurer qu'ils répondent aux besoins de l'entreprise.
  - La reprise des technologies et des informations doit souvent être combinée pour créer un système complet nécessaire au support des processus critiques. Ainsi, le rétablissement d'une application peut nécessiter celui de l'application bureautique, de l'application serveur, du matériel associé au serveur, du système d'exploitation du serveur, des serveurs d'infrastructure, du centre de ressources informatiques, des connexions réseau avec les tiers, etc.
- Les prestataires internes et externes de services des SI doivent décrire les services de reprise qu'ils fournissent, en précisant notamment :
  - Les opérations de reprise dont le prestataire de services a la responsabilité, et toute éventuelle limitation de la reprise.
  - Les opérations de reprise dont l'organisation a la responsabilité (par exemple la reconstitution des données perdues).
  - La façon dont l'organisation et le prestataire de services communiqueront durant un sinistre.
  - Les contrats avec des tiers (prestataires de services d'applications, par exemple) ou les accords sur le niveau de service avec le prestataire interne.
  - L'étendue de leurs efforts de reprise (systèmes, données, réseau, etc.).
  - Leur stratégie de reprise.
  - Leurs DMIA et leurs DMPA.
  - Le coût de leurs solutions, services et tests de reprise, ainsi que celui de la déclaration du sinistre.
  - La fréquence de leurs tests de reprise.
- Des éléments de l'environnement peuvent être restaurés grâce à des solutions qui ne seraient normalement pas utilisées dans un centre de ressources informatiques. Ainsi, il se peut que certaines données ne soient pas récupérables dans un premier temps (telles que les grandes bibliothèques d'images), ce qui signifie qu'elles seraient indisponibles (elles peuvent, par exemple, générer des messages d'erreur).
- Les stratégies de reprise de chaque SI ou composante de SI doivent être élaborées indépendamment, sans cohérence nécessaire avec celles des autres SI. Il importe toutefois que les éléments fonctionnant ensemble pour former un système soient hébergés dans le même lieu ou dans plusieurs endroits disposant d'une bande passante suffisante sur le réseau. Ainsi, il se peut que le courrier électronique soit rétabli au niveau d'un grand centre de ressources informatiques principal, que la réplication des fichiers soit effectuée au niveau d'un autre site, sur un serveur, dans la région, que certaines applications et certains services (ingénierie…) soient externalisés temporai-

rement au cours d'un sinistre, que les applications locales soient restaurées grâce à un ordinateur individuel au lieu d'un serveur, etc. Il s'agit de trouver la solution de reprise la meilleure et la plus économique pour chaque système, même si les différentes solutions sont disséminées à travers le monde. Seul impératif : quel que soit l'endroit où les systèmes sont rétablis, ils doivent être accessibles aux utilisateurs, et toutes les composantes d'un système doivent fonctionner ensemble.

- Les normes de conformité et de sécurité de l'information doivent être prises en compte lors de la conception des solutions de reprise. Ces dernières ne doivent pas induire de niveaux déraisonnables de sécurité ni de risques de non-conformité. Certains contrôles de sécurité et de conformité seront assouplis si une catastrophe réelle survient. Cet assouplissement doit découler d'une décision mûrement réfléchie, en toute connaissance des risques existant dans l'environnement de reprise. Les solutions de reprise sont destinées à réduire le risque associé à la perte de disponibilité. Elles doivent néanmoins être mises en balance avec le besoin d'intégrité et de confidentialité.

B. Solutions et sites de reprise

Voici une liste de solutions et sites de reprise couramment utilisés.

- Plan / dispositifs de secours immédiat (*hot recovery*).
  - Un plan de reprise existe.
  - Les ressources pour la reprise sont disponibles sur le(s) site(s) de reprise, et les données synchronisées en temps réel pour permettre la reprise du système immédiatement ou en quelques heures.
  - La reprise d'activité prend habituellement de quelques minutes à un jour.
- Plan / dispositifs de reprise à chaud (*warm recovery*).
  - Un plan de reprise existe.
  - Les ressources pour la reprise (systèmes ne servant pas à la production, matériel informatique de réserve, etc.) sont disponibles sur le(s) site(s) de reprise, mais peuvent devoir être reconfigurées pour soutenir le système de production lorsqu'un sinistre survient.
  - Certaines données doivent être restaurées (certainement à partir de sauvegardes sur bande ou autres).
  - La reprise d'activité prend habituellement de 2 à 13 jours.
- Plan / dispositifs de reprise à froid (*cold recovery*).
  - Un plan de reprise existe.
  - Un ou plusieurs site(s) de reprise offrant l'espace et l'infrastructure de base nécessaires à la reprise ont été identifiés.
  - Les ressources pour la reprise (serveurs, par exemple) ne sont pas disponibles sur le(s) site(s) de reprise et devront donc probablement être achetées.
  - Les données devront probablement être rétablies (certainement à partir de sauvegardes sur bande).
  - La reprise d'activité prend habituellement de 14 à 30 jours.
- Pas de plan / dispositifs de reprise.
  - Aucun plan de reprise n'existe.
  - Les ressources pour la reprise et les processus de reprise des données n'ont pas été définis.
  - Des plans de sauvegarde des données existent pour permettre la reprise des données critiques à un moment ou à un autre dans l'avenir.
  - Il existe un risque que les systèmes et les processus de l'entreprise qu'ils supportent ne puissent jamais être rétablis, ou qu'ils retardent largement la reprise.

Le sponsor de la gestion de la continuité et une équipe adéquate de responsables doivent valider les solutions de reprise des SI pour le champ des opérations les concernant. Ces responsables devant veiller à la mise en œuvre des solutions de continuité et de reprise d'activité dans toute l'organisation, ils doivent répondre des solutions de reprise des SI pour leur équipe.

5.6 Sensibilisation et formation

L'information et la sensibilisation permettent de préparer efficacement le personnel à la reprise. Il convient de dispenser une fois par an, au minimum, une formation de sensibilisation, afin que les membres du personnel comprennent leurs rôles et le dispositif d'intervention d'urgence pour leur site ou dans la région. La formation à la gestion de crise, notamment à la prise de décisions par l'équipe de direction et à la communication pour la gestion, est également indispensable.

Le programme de gestion de la continuité nécessite des degrés variables de connaissances, en fonction du rôle des différents participants et des stratégies d'externalisation. Voici des exemples des rôles et des connaissances requises pour chaque rôle :

- Le sponsor de la gestion de la continuité doit :
  - Comprendre les concepts et la philosophie de gestion de la continuité.

- Le responsable de la gestion de la continuité doit :
  - Comprendre la gestion d'urgence (gestion de crise, intervention d'urgence, gestion de la continuité d'activité).
  - Obtenir la certification CBCP (*Certified Business Continuity Professional*) auprès de DRI International (DRII), du *Business Continuity Institute* (BCI) ou d'un organisme équivalent (cette qualification est optionnelle pour les responsables de la gestion de la continuité des unités d'affaires, mais obligatoire pour le directeur de la gestion de la continuité à l'échelle de l'organisation).
  - Établir le programme de gestion de la continuité et / ou s'occuper du déploiement (dans l'idéal, sans aller à l'encontre de la méthodologie de l'organisation, par exemple en ce qui concerne l'efficience opérationnelle, la sécurité et / ou d'autres processus connexes).
- Les coordinateurs de la gestion de la continuité doivent :
  - Bien connaître la méthodologie des processus liés à la gestion de la continuité dans l'organisation (connaissance généralement acquise via une formation interne ou externe).
- Le consultant (interne ou externe) en gestion de la continuité doit :
  - Obtenir un certificat CBCP ou MBCP (*Master Business Continuity Professional*) auprès de DRII, du BCI ou d'un organisme équivalent.
  - Disposer d'une vaste expérience des domaines suivants : évaluation des risques, analyse d'impact, planification de la reprise d'activité, tests, etc.
- Le personnel chargé de gérer la continuité doit :
  - Bien comprendre les concepts et la philosophie de gestion de la continuité.
  - Comprendre les procédures de communication dans une situation d'urgence.
  - Connaître le dispositif d'intervention d'urgence pour son site ou pour la région.

Les tests constituent la principale méthode servant à former les membres du personnel à l'exécution effective des plans de reprise et de leurs rôles, ainsi qu'à identifier les lacunes et les points faibles. Voir « Entraînement à la continuité d'activité » (page 17) pour une description des différents types de tests.

5.7 Maintenance du programme de gestion de la continuité

La négligence est l'un des obstacles les plus fréquents empêchant les organisations de bien se préparer à la continuité d'activité. Souvent, les organisations consacrent du temps et des sommes considérables à l'élaboration de plans qui ne seront jamais tenus à jour. Comme tout plan opérationnel, les plans de continuité d'activité et de gestion de crise s'atrophient au fil du temps et perdent en efficacité s'ils ne tiennent pas compte des changements dans les priorités de l'entreprise, dans le personnel, dans les processus, dans la technologie et dans l'environnement. Dans certains cas, la « tenue à jour » se limite à changer les dates sur un plan sans en réviser le contenu. Dans tous les cas, l'audit interne doit se concentrer sur la tenue à jour des moyens alloués à la continuité d'activité / gestion de crise, et non se contenter de l'actualisation superficielle d'un document.

Voici quelques techniques permettant d'évaluer la tenue à jour du document relatif à la continuité d'activité :

- Évaluer l'historique des changements apportés à ce document, afin de déterminer si des mises à jour ont été enregistrées.
- Réviser les exigences de mise à jour de façon à s'assurer que la tenue à jour de chaque composante est confiée à une personne spécifique et que la direction fournit des lignes directrices pour permettre à ces personnes de maintenir efficacement les dispositifs de continuité.
- Réviser les hypothèses de continuité d'activité pour vérifier qu'elles cadrent avec les exigences opérationnelles du moment. Il faut revoir ces hypothèses lorsque des changements interviennent : sites supplémentaires, concentrations nouvelles du risque (par exemple, un nouveau scénario de catastrophe devient crédible), recours à des tiers nouveaux / différents ou opérations dans de nouveaux pays, par exemple.
- Réviser les changements apportés aux hypothèses de continuité d'activité, afin de s'assurer que chacun d'eux est justifié.
- Réviser la date de l'analyse d'impact (BIA) pour vérifier que les plans de continuité reposent sur des éléments suffisamment à jour pour donner des indications appropriées.
- Contacter les personnes responsables des tâches énoncées dans les plans, afin de déterminer si elles comprennent bien les exigences définies et si elles sont compétentes pour mener à bien ces tâches. Dans de nombreux cas, les personnes désignées dans les plans (surtout les plans qui existent depuis plusieurs années) sont les remplaçants de leurs prédécesseurs uniquement dans l'intitulé de la fonction et n'ont pas reçu la même formation dont leurs précédesseurs avaient bénéficié lors de l'introduction d'un programme de gestion de la continuité et / ou du plan de continuité.
- Réviser la structure / configuration du document relatif à la continuité d'activité, afin de déterminer dans

quelle mesure il tient précisément compte du modèle et de la structure organisationnelle actuelle.

- Repérer les termes tels que « actuel » et « d'aujourd'hui » et évaluer si le contenu correspondant suit réellement les évolutions de l'organisation, en particulier dans le cas d'un document disponible au format électronique.
- Réviser les résultats des exercices / tests et les comptes rendus correspondants, afin de rechercher des anomalies (écarts, par exemple) nécessitant des mesures correctives.
- Évaluer les dispositifs prévus dans le programme de gestion de la continuité et pour la reprise de l'activité, afin de s'assurer qu'ils ont été révisés pour corriger les éventuels écarts et qu'ils sont bien mis en œuvre.

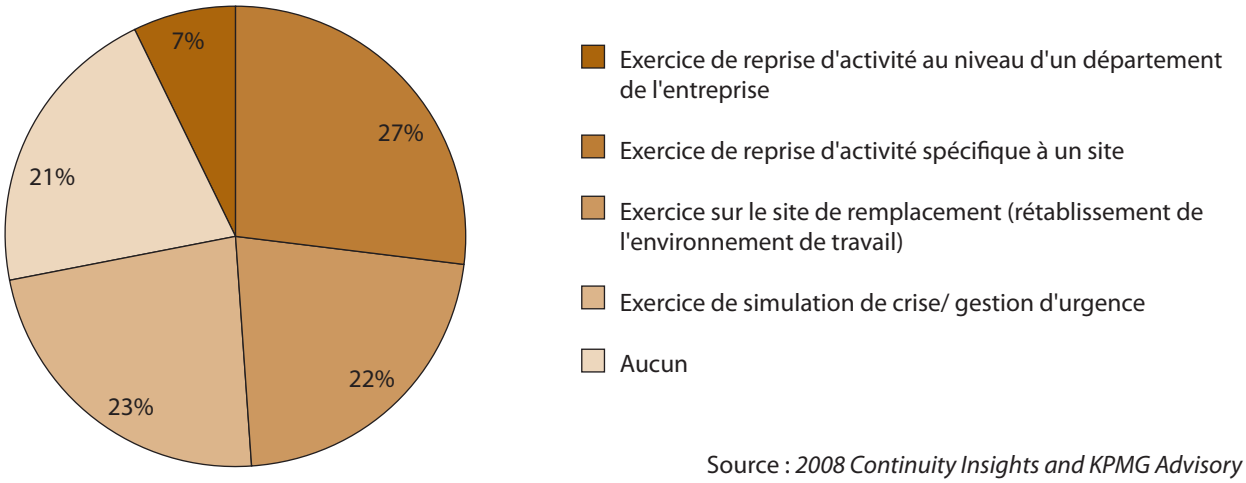
5.8 Entraînement à la continuité d'activité

Les exercices, ou tests, sont généralement considérés comme la méthode la plus efficace pour tenir à jour et rendre opérationnel un programme de gestion de la continuité et des plans de continuité. Certaines organisations distinguent les « *exercices* » des « *tests* », mais il n'est pas obligatoire d'employer ces termes dans des contextes spécifiques. Quels que soient les termes utilisés, les tests des plans doivent avoir pour objectif d'améliorer les performances de l'organisation lors de la survenue réelle d'un événement. Il importe de noter qu'il existe de nombreux types d'exercices / tests qui, utilisés de façon appropriée, donnent une assurance et créent de la valeur ajoutée. Toutes les grandes normes ayant trait à la continuité d'activité imposent qu'un ensemble d'exercices / de tests, sous une forme ou une autre, fasse partie intégrante du programme de gestion de la continuité. En règle générale, il convient de procéder au moins chaque année à un exercice grandeur nature des programmes de gestion de la continuité et des plans de continuité. Des tests plus fréquents peuvent être nécessaires dans des environnements complexes et pour ceux qui auraient un impact considérable (pertes, par exemple) sur l'organisation. Plusieurs tests élémentaires doivent également être programmés à des intervalles réguliers tout au long de l'année.

Les exigences relatives aux exercices / tests doivent être présentées dans le plan lui-même ou dans la politique de gestion de la continuité au niveau de l'entité. La plupart des normes sur lesquelles reposent les programmes de gestion de la continuité énoncent trois conditions de base pour un dispositif de tests :

- Les tests doivent être organisés périodiquement. Leur fréquence effective est déterminée par le comité directeur de gestion de la continuité et dépend des buts et objectifs du programme.
- Les tests doivent porter sur plusieurs menaces / scénarios et sur différents éléments du programme de continuité. Il est possible de traiter ces aspects dans une série d'exercices annuels reposant sur une large base ou via des tests ciblant davantage un site ou le test d'une composante particulière.
- Il faut prévoir une méthode qui permettra de suivre les éventuels problèmes et écarts non découverts pendant les tests, ainsi que les mesures prises pour y remédier.

Sur quels éléments de votre programme de gestion de la continuité avez-vous organisé des exercices au moins une fois au cours de l'année écoulée?
(Sélectionnez toutes les réponses possibles)



Source : *2008 Continuity Insights and KPMG Advisory Services Business Continuity Benchmarking Report.*

Figure 5. Exercices portant sur des éléments du programme de gestion de la continuité.

GTAG®

The Institute of Internal Auditors

A. Types d'exercices

Type d'exercices	Description et objectifs
Contrôle de programmation ou mission d'audit de conformité	C'est le type d'exercice / de test le moins invasif qui reste généralement considéré comme un test. Un contrôle de programmation fait habituellement intervenir uniquement le propriétaire du plan et, parfois, un tiers neutre. Cet effort vise seulement à s'assurer que le contenu du plan n'est pas devenu obsolète (par exemple, les informations sur les personnes à contacter) et que l'orientation globale du plan demeure pertinente. En principe, il consiste simplement à lire le plan page par page et à l'actualiser. Objectifs : • S'assurer que la liste des membres de l'équipe désignés reste d'actualité. • S'assurer que les coordonnées des contacts internes et externes sont à jour.
Revue d'orientation ou du plan	Tout particulièrement dans le cas où un plan de continuité d'activité ou de gestion de crise a été récemment adopté ou nettement enrichi, il est utile de procéder à son examen informel avec les personnes censées le mettre en œuvre. La revue du plan consiste notamment en une réunion animée par un chef d'équipe désigné. En temps normal, ce type d'examen de faible intensité ne constitue pas un « test » des exigences relatives à la politique de gestion de la continuité d'une organisation. Objectifs : • S'assurer que les membres de l'équipe comprennent leurs rôles nouveaux / actualisés. • S'assurer que les membres de l'équipe comprennent le contenu et le format du plan de base.
Exercice sur table	Dans de nombreux cas, il est utile de réunir tous les membres de l'équipe de continuité d'activité / gestion de crise pour une séance au cours de laquelle, ensemble, ils élaboreront un scénario destiné à identifier les problèmes et s'attacheront à les résoudre. En général, ces exercices durent de deux à quatre heures et sont animés soit par le responsable de la continuité d'activité / gestion de crise, soit par un tiers indépendant. Ils se terminent par une analyse critique formelle, qui détermine de manière détaillée si les objectifs prédéfinis pour l'exercice ont été atteints et qui pointe les lacunes mises au jour à cette occasion, avec présentation d'un calendrier de mesures correctives ainsi que des actions suivantes à mettre en œuvre. Objectifs : • Aider les membres de l'équipe à comprendre l'importance de leurs rôles et responsabilités. • Constater l'intérêt à résoudre dans une configuration d'équipe des problèmes de continuité ou liés à une crise. • Identifier les lacunes spécifiques de la planification / formation dans les domaines fonctionnels.
Test de la communication	La communication est un élément clé d'un processus de gestion de la continuité. En effet, l'incapacité à communiquer de manière précise avec les principales parties prenantes constitue une cause fréquente d'échec des interventions en situation de crise. Ce type de test diffère largement selon le niveau de planification de la communication et d'automatisation du processus de communication de crise. Les entreprises qui ont déployé un outil de notification de masse retirent un double avantage de cet exercice : les performances de ce système sont évaluées, et les participants savent comment la notification sera reçue. En général, ce test impose de contacter réellement les partenaires et le personnel de l'entreprise, et ne se limite pas à l'examen des informations sur ces personnes à contacter. Objectifs : • Valider les coordonnées des principales parties prenantes.

Type d'exercices	Description et objectifs
Test de la communication (*suite*)	• Former les participants à l'utilisation d'un outil de notification de masse et à tout rôle qu'ils devront exercer en situation d'intervention. • Configurer correctement les outils de notification de masse. • Identifier les lacunes / entraves dans la communication qui risquent de faire obstacle à la communication lors d'un sinistre.
Environnement informatique Revue de l'environnement informatique (systèmes et applications)	Ce test consiste à simuler une catastrophe, annoncée ou non, et à exécuter les procédures documentées pour la reprise des systèmes. Nombre d'environnements informatiques sont extrêmement complexes, et certains plans peuvent être axés sur le rétablissement d'applications ou de systèmes spécifiques plutôt que la récupération de l'ensemble du centre de ressources informatique. Dans ces conditions, tester la perte d'un centre de ressources informatiques pourrait entraîner de fortes perturbations et des coûts très élevés. Une revue bien conçue peut donc permettre de rassembler, de la seule manière possible sur le plan pratique, des parties prenantes disparates. Objectifs : • Vérifier que les systèmes et données critiques peuvent être rétablis lors d'un sinistre de large portée. • Déterminer si les ressources internes prévues dans les plans relatifs aux différents systèmes ou applications seront opérantes si plusieurs systèmes / applications sont perdus. • Coordonner l'utilisation des ressources d'intervention / de reprise entre plusieurs sites / pôles d'activité. • S'assurer de l'adéquation des ressources (ressources humaines et achats, notamment) destinées à soutenir l'intervention au niveau des SI.
Test du site de remplacement	Ce test de tous les éléments d'un site de remplacement qui sont destinés à la reprise d'activité doit inclure un test de la capacité de l'organisation à transférer son personnel sur ce site, ainsi qu'une validation du fonctionnement des processus de reprise et des SI sur ce même site, tel que prévu. Objectifs : • Démontrer la possibilité effective de continuer à mettre en œuvre les processus clés sur le site de remplacement. • Déterminer si les contrôles de la confidentialité des données, de la sécurité et financiers peuvent être maintenus dans l'environnement opérationnel de remplacement. • Former les participants à toutes les procédures révisées en vue de l'exécution des processus clés sur le site de remplacement. • Évaluer si les SI du site de remplacement sont suffisants et efficaces. • S'assurer que le plan de transport du personnel est raisonnable dans les différents scénarios de catastrophes définis lors de l'évaluation des risques de non-gestion de la continuité d'activité.
Test de bout en bout	Ce test des installations du site de remplacement doit porter à la fois sur l'activité commerciale et sur les SI. À la différence d'un test du site de remplacement, un test de bout en bout prend en compte les fournisseurs / partenaires commerciaux et clients (internes et externes). Il sert habituellement à valider la connectivité avec le site de production de l'organisation. Objectif : • Démontrer la capacité à exécuter sans problème significatif les processus clés à un niveau prédéfini. Un test de bout en bout ne nécessite pas de démontrer une capacité opérationnelle de 100 %. Cependant, la pratique prédominante consiste à comparer la capacité effective de la stratégie de continuité aux attentes de performance théoriques ou documentées dans le plan de continuité.

B. Fréquence des exercices

L'encadrement de l'audit interne se demande souvent s'il existe une « bonne » fréquence pour les exercices / tests du programme de gestion de la continuité. La fréquence n'est pas le seul aspect à considérer, car la réalisation d'un même test deux fois par an engendre rapidement la stagnation des résultats et une lassitude des participants. Comme dans de nombreux domaines de contrôle, on considère généralement que la fréquence doit être suffisante pour que le programme gagne progressivement en maturité. La plupart des organisations matures testent leurs processus de continuité une ou deux fois par an, mais cette fréquence peut être augmentée s'il existe certains facteurs, par exemple :

- Des changements dans les processus.
- Des changements technologiques.
- Un changement dans les membres de l'équipe chargée du plan de continuité.
- L'anticipation de certains événements susceptibles de provoquer une interruption d'activité (par exemple, le début de la saison des cyclones ou des signes indiquant qu'une pandémie est imminente).

Quelle que soit leur fréquence effective, le responsable de l'audit interne doit avoir pour priorité de veiller à ce que les exercices / tests effectués contribuent à l'amélioration continue du programme.

5.9 Communication de crise

La planification de la communication de crise fait partie intégrante d'un programme global de gestion de la continuité ; il est le plus souvent coordonné par le service de communication de l'entreprise, par le service des relations publiques ou par un autre service employant des professionnels de la communication. Lorsqu'il existe un plan de communication de crise, il est fréquent qu'il décrive les façons de gérer les messages adressés aux médias à la suite d'une crise. Dans tous les cas, la communication de crise sera, de préférence, une fonction relevant du processus général de gestion de crise, plutôt qu'un processus distinct.

Malheureusement, les contacts avec les médias ne constituent qu'une petite fraction de la communication de crise en situation réelle. Même s'ils sont essentiels et largement tournés vers le grand public, des lacunes dans des aspects « moins importants » de la communication de crise peuvent avoir des effets tout aussi dévastateurs dans le cas d'une gestion ou d'une mise en œuvre inappropriée.

Un bon plan de communication de crise permet de communiquer, en prenant les devants, un message global à diverses parties prenantes, d'une manière pertinente pour ces différents destinataires. Les points de la communication qui intéressent la sphère financière ne sont pas forcément ceux qui importent au personnel ou au voisinage. Le message central doit toutefois être cohérent. Bien qu'il soit impossible d'anticiper tous les aspects de la communication de crise à déployer au cours d'un événement, les plans et les efforts de préparation doivent s'adresser à certains publics :

- Les membres de l'équipe d'intervention de l'organisation.
- Les cadres responsables de la continuité des opérations et de l'interface avec le personnel.
- Le personnel opérationnel, dont la compréhension des problèmes plus globaux est parfois moins complète que celle dont dispose l'équipe de direction.
- Les membres de la famille du personnel, surtout ceux directement concernés par l'événement ou par l'intervention de l'organisation.
- Les médias nationaux, y compris du secteur financier, qui s'intéressent principalement à la gestion de l'événement par la direction.
- Les médias locaux (presse écrite, radio et télévision), qui couvrent régulièrement les activités de l'organisation dans un large éventail de domaines.
- Les investisseurs, tout particulièrement les investisseurs institutionnels, qui souhaitent la transparence en ce qui concerne les ramifications à court et à long terme d'un incident.
- Les autorités locales, régionales et nationales qui prêtent attention à la viabilité à long terme de l'assiette fiscale et à d'autres effets positifs de l'organisation sur leurs administrés.
- Les instances de réglementation qui veillent au respect permanent de la conformité, y compris durant la phase de reprise de l'activité.
- Le voisinage, qui peut être affecté par un événement, par l'intervention de l'organisation ou par les efforts déployés par les autorités pour limiter l'impact global de l'incident au niveau local.

5.10 Coordination avec les organismes extérieurs

Aucun des aspects de la gestion de la continuité ne peut exister dans le vide. Outre la coordination des différentes disciplines qu'elles représentent, il est impératif que le processus de planification tienne compte des points de coordination avec les entités extérieures. Les administrations publiques souhaitent que les organisations du secteur privé soient bien préparées aux incidents. Ainsi, les États-Unis ont voté en 2007 la *Public Law* 110-53, qui impose notamment l'élaboration d'une norme de préparation volontaire aux situations d'urgence à l'aune de laquelle les organisations du secteur privé peuvent mesurer leurs efforts de préparation à une crise. Au Royaume-Uni, le *Civil Contingencies Act* présente les dispositifs grâce auxquels les autorités travailleront désormais avec le secteur privé au cours d'une situation

d'urgence. D'autres pays ont adopté des lois analogues, qui décrivent ce qu'ils attendent d'eux-mêmes et du secteur privé pendant une crise. Il n'y a pas de façon « appropriée » de documenter chacun des points de contact avec ces organismes extérieurs, mais, au minimum, la planification doit répondre aux questions suivantes :

- Quelles entités gouvernementales faut-il contacter si un événement s'est produit ?
- Quels sont les seuils existants de notification obligatoire, et dans quelles circonstances l'organisation peut-elle prendre l'initiative de la notification ?
- De quoi s'occupe chaque organisme, et dans quelle mesure est-ce différent ou similaire d'un organisme à l'autre ?
- Comment l'organisation peut-elle recourir aux entités gouvernementales durant la planification ou les exercices, afin de profiter de leur expérience sans compromettre son indépendance ?
- Quelles sont les exigences définies par les instances de contrôle pour les programmes de gestion de la continuité, et comment l'organisation fait-elle savoir qu'elle en tient compte ?
- Existe-t-il des organismes extérieurs qui doivent examiner ou autoriser les stratégies de continuité telles que la production sur un site non certifié, l'exécution de fonctions non régulées dans une zone géographique distincte ou la modification des conditions d'importation de matières premières ou de produits finis ?
- Au sein de l'organisation, qui assurera l'interface avec chaque entité gouvernementale, et comment ?

Pour répondre à ces questions et à d'autres, l'idéal est que l'encadrement soit responsable du programme de gestion de la continuité et communique avec les organismes extérieurs à ce propos. Si ces organismes ne spécifient pas à la direction de l'entreprise leurs attentes vis-à-vis de la gestion de la continuité, cela ne signifie pas pour autant qu'ils n'ont pas d'attentes. Pour qu'ils agissent en partenaires au cours d'un incident, il est crucial de mettre en place, à l'avance, une communication et une coordination avec eux.

6. Interventions d'urgence

Le concept d'interventions d'urgence regroupe généralement les activités pratiques et la planification tactique destinées à protéger les vies humaines et les biens immédiatement après la survenue d'un événement. La plupart des pays industrialisés demandent instamment aux grandes organisations d'élaborer des plans d'intervention d'urgence, et les différents secteurs doivent respecter des impératifs spécifiques. Ce sont généralement les pouvoirs publics qui définissent ces impératifs, mais il existe aussi de nombreux principes émanant de groupements sectoriels nationaux ou internationaux. Parmi les principaux éléments d'un programme d'interventions d'urgence figurent :

- La planification de l'évacuation et le regroupement.
- Les protocoles d'escalade.
- L'évaluation des dégâts et les comptes rendus.
- Les interventions en présence de matières dangereuses et les mesures de lutte contre la pollution.
- Les interventions médicales.
- Le sauvetage et la récupération.
- Des interventions particulières : sapeurs-pompiers, premiers secours, opérations de sauvetage dans un espace clos ou à forte déclivité, etc.

Habituellement, on ne demande pas au responsable de l'audit interne d'examiner cet aspect de la préparation comme un élément autonome. Par conséquent, dans n'importe quel examen ou consultation portant sur la gestion de la continuité d'activité, il est essentiel de traiter du niveau d'intégration et de coopération avec les ressources internes chargées des interventions d'urgence. Étant donné que de nombreuses mesures de continuité d'activité commencent par des interventions d'urgence, l'absence de coordination des plans et des activités non seulement pèse sur la capacité de l'organisation à remédier aux conséquences immédiates d'un événement, mais rend également la prise de décision à long terme plus difficile car on omet à tort une information essentielle sur l'origine et les caractéristiques de l'interruption d'activité.

Étant donné que de nombreux plans d'intervention d'urgence se concentrent sur la sécurité des personnes en excluant quasiment toutes les autres considérations, lorsque l'on coordonne les initiatives visant la continuité et les interventions d'urgence, il faut souvent déterminer comment les responsables peuvent tenir compte des priorités de chacun sans perdre de vue leur objectif premier. En raison de sa neutralité et de son approche consultative, l'audit interne peut apporter de la valeur sur ce point. Dans la plupart des cas, les équipes chargées de la continuité d'activité peuvent utiliser les informations qui ont déjà été rassemblées par une équipe d'intervention d'urgence afin d'étoffer les plans de continuité, et les équipes d'intervention d'urgence seront mieux informées de l'influence de leurs actions sur la résilience opérationnelle et financière, ainsi que sur la réputation de l'organisation.

Les organisations qui, en raison de la nature de leurs opérations, ont des besoins importants en matière d'intervention d'urgence recourent presque toujours à une approche structurée. Le modèle de l'équipe de gestion d'incident est fréquemment utilisé. Un gestionnaire d'incident est désigné pour superviser tous les aspects de l'intervention d'urgence (logistique, planification, rapports de situation et intervention opérationnelle). La plupart des organisations qui utilisent ce modèle adaptent leur approche, mais conservent les principes clés de l'unité de gestion et des rôles et responsabilités clairement définis. Vous trouverez des informations complémentaires sur ce modèle à l'adresse : http://www.fema.gov/txt/nims/nims_ ics_position_paper.txt.

Si l'on doit inclure dans un plan d'audit la coordination des programmes de continuité d'activité et d'intervention d'urgence, voici quelques grandes questions auxquelles il faut répondre :

- A quelle fréquence se réunissent les propriétaires du programme pour discuter des problèmes et de leurs préoccupations ?
- Les propriétaires du programme ont-ils rencontré les responsables locaux des interventions d'urgence pour trouver un consensus sur la manière de gérer des événements d'ampleur variable afin d'en minimaliser les conséquences immédiates et à long terme ?
- Le coordonnateur des interventions d'urgence est-il suffisamment influent pour faire modifier, si nécessaire, les stratégies de continuité d'activité ?
- La direction générale a-t-elle clairement délimité les responsabilités en matière d'intervention d'urgence et de continuité d'activité au sein de l'organisation ?
- Existe-t-il des protocoles concrets pour le relais de l'information et les relations extérieures à mesure que la phase d'intervention d'urgence perd en importance au profit de la continuité d'activité ?
- Si l'on a recours à une équipe de gestion des incidents, le responsable du programme de continuité d'activité joue-t-il un rôle au sein de cette équipe ?

7. Gestion de crise

La *gestion de crise* est de loin l'une des expressions les plus mal comprises dans le domaine de la gestion de la continuité d'activité. Pour certaines organisations, il s'agit de la planification extrêmement tactique que nous venons de décrire comme étant l'intervention d'urgence. D'autres organisations emploient cette expression pour désigner des événements liés à des problèmes de sécurité physique. D'autres encore la définissent comme étant le plan élaboré par l'encadrement pour faire face à des événements importants au niveau de l'entité, mais qui, en réalité, ne traite que des aspects de la communication de crise. Dans le présent GTAG, nous utiliserons cette expression pour décrire le plan, élaboré au niveau de l'entité, pour remédier aux conséquences immédiates et graves d'une catastrophe pour une organisation.

La plupart des plans de gestion de crise doivent pouvoir être activés pour n'importe quel incident, quel qu'en soit l'impact. Dans bien des cas, des seuils spécifiques sont fixés à l'avance pour différents types de conséquences afin d'éliminer la subjectivité souvent présente dans la remontée d'informations sur un événement. Ces critères doivent tenir compte des conséquences humaines, financières et opérationnelles et être assez clairs pour permettre aux membres de l'encadrement, où qu'ils soient, de savoir si une remontée d'information à l'équipe de gestion de crise se justifie ou non. De même, l'utilisation systématique de ces seuils dans toute l'entité permet à l'équipe de gestion de crise de savoir que, si elle n'a pas encore été contactée, c'est que l'événement n'a pas encore dépassé les seuils préétablis.

Ces seuils présentent un autre avantage important : ils différencient un événement relatif à la continuité d'activité d'une crise au niveau de l'entité. Un petit incendie ou la perte d'un fournisseur clé peuvent avoir des conséquences importantes pour une activité ou pour un site, mais ils ne constituent pas nécessairement, pour l'ensemble de l'entité, une crise qui nécessite l'entrée en scène de l'équipe de gestion de crise. Des seuils minutieusement définis permettent aux responsables de l'unité d'affaires (ou aux responsables régionaux) d'agir en vue du redémarrage de l'activité sans se demander si la direction générale y trouvera à redire.

Dans la plupart des entreprises qui ont mis en place de longue date des programmes de gestion de crise, on observe une capacité de commandement bien définie et bien intégrée par le personnel. Lors d'un événement, en particulier s'il est complexe, le chaos est général. Il n'y a pas suffisamment d'informations fiables et assez rapidement disponibles pour que la direction puisse prendre des décisions totalement exactes à chaque fois. Les organisations en quête d'excellence dans la gestion des crises développent et testent à l'avance un système capable d'absorber les informations disponibles, d'éliminer le « bruit », de diffuser l'information rapidement et en toute sécurité, et de maximiser la capacité décisionnelle.

Outre les protocoles de remontée des informations, la capacité à commander les individus et le contrôle des processus et de l'information, les programmes de gestion de crise efficaces peuvent notamment inclure les éléments suivants :

- Intégration dans le programme global de gestion de crise des actions spécifiques, comme le retrait de produits du marché, les incidents de sécurité (en particulier internationaux) et les interventions propres à un secteur (tel que l'aviation). En général, les entreprises exposées à ces risques élaboreront des plans pour y remédier, mais ces plans ne sont pas toujours mis en relation avec le programme de gestion de crise au niveau de l'entité.
- Aide aux salariés affectés par une catastrophe, par exemple une aide psychologique, une aide à la famille ou une aide financière pendant un événement à l'échelle régionale. L'aide peut aussi prendre la forme d'incitations à se déplacer ou à se délocaliser temporairement en cas d'urgence.
- Prise en compte des attentes du conseil lors de l'intervention après un incident et présentation de rapports au conseil pendant l'intervention.
- Gestion des questions relatives aux actionnaires, notamment en termes de responsabilité, après un événement, y compris les erreurs et omissions, ainsi que les questions de responsabilité des administrateurs et des directeurs.
- Examen conjoint de la gestion de crise et de la continuité d'activité afin que chaque programme puisse s'appuyer sur les forces de l'autre et que l'effort global puisse être unifié.
- Délimitation des pouvoirs lorsque certaines opérations sont gérées conjointement et / ou existent dans plusieurs pays. La responsabilité juridique peut être transférée depuis une co-entreprise ou un pays si des décisions sont prises par une autre entité juridique ou dans un autre pays. Cet aspect est très important si l'équipe chargée de la gestion de crise est basée aux États-Unis, car ce pays est connu pour être procédurier.

8. Conclusion / Résumé

La gestion de la continuité d'activité constitue un important programme de gestion des risques, destiné à protéger les entreprises des conséquences potentiellement significatives liées aux événements susceptibles de perturber des processus critiques. Le responsable de l'audit interne peut aider l'organisation à comprendre ces risques et les solutions permettant d'élaborer un programme efficace de gestion de la continuité d'activité. Dans toute l'organisation, l'encadrement doit être responsable de la gestion correcte des risques associés à la perturbation des opérations de l'entreprise et des fonctions y afférentes au sein de l'organisation.

Un programme de gestion de la continuité d'activité constitue le cadre permettant de prendre les bonnes décisions pour atténuer les risques et améliorer la résilience de l'organisation. Les processus critiques doivent être rétablis afin de permettre le redémarrage des opérations critiques de l'entreprise. Le programme de gestion de la continuité d'activité permet à une organisation de conserver des dispositifs de reprise, y compris des dispositifs et des connaissances organisationnels, de rétablir ses systèmes et l'information, de restaurer et d'acquérir des ressources, de gérer ses fournisseurs et de procéder à l'alignement sur les processus de gestion des situations d'urgence.

Le programme de gestion de la continuité d'activité doit être conçu de manière à maintenir et à enrichir sans cesse les dispositifs de continuité d'activité. Pour que ces dispositifs soient maintenus au sein de l'organisation, il faut une formation régulière du personnel, des exercices périodiques (y compris remédier à toutes les lacunes identifiées et obtenir l'engagement de la direction envers le programme), l'évaluation par l'audit du programme de gestion de la continuité d'activité et des dispositifs des unités d'affaires, ainsi que l'amélioration continue du programme.

9. Annexe

9.1 Exemple de guide d'audit

Le *Federal Financial Institutions Examination Council* a publié un excellent guide intitulé *Business Continuity Planning Booklet* (mars 2008), disponible sur son site Web à l'adresse : www.ffiec.gov. Voici les principaux sujets développés dans ce guide.

- Déterminer le périmètre et les objectifs de l'examen du programme de continuité d'activité.
- Déterminer s'il existe un plan de continuité adapté au niveau de l'ensemble de l'entreprise.
- Déterminer si le conseil d'administration et la direction générale supervisent et soutiennent suffisamment le plan de continuité.
- Déterminer si une analyse d'impact et une évaluation des risques suffisantes ont été réalisées.
- Déterminer si une gestion des risques adaptée, pour l'ensemble du processus de continuité, est opérationnelle.
- Déterminer si le(s) plan(s) de continuité comporte(nt) des tests appropriés permettant le maintien, le redémarrage et / ou la récupération du ou des processus concerné(s).
- Déterminer si les SI disposent d'un plan de continuité correctement présenté dans des rapports et qui complète ceux de l'entreprise et les plans des autres départements.
- Déterminer si le(s) plan(s) de continuité inclu(en)t des sauvegardes et récupérations du matériel appropriées.
- Déterminer si la continuité d'activité comporte des sauvegardes et récupérations des logiciels appropriées.
- Déterminer si le(s) plan(s) inclu(en)t une préparation appropriée qui garantit que les processus de reprise du centre de ressources informatiques fonctionneront comme prévu.
- Déterminer si le(s) plan(s) de continuité inclu(en)t des procédures de sécurité appropriées.
- Déterminer si le(s) plan(s) de continuité porte(nt) sur les activités externalisées critiques.
- Discuter des actions correctives et en communiquer les résultats.

9.2 Normes et principes directeurs portant sur la gestion de la continuité d'activité

Organisation / autorité de contrôle	Norme	Description des normes
Business Continuity Institute (BCI)		Les 10 compétences du *Business Continuity Institute*
Organisation internationale de normalisation (ISO)	ISO 9000	Gestion de la qualité
	ISO 14001	Système de management environnemental
	ISO 27002	Code de bonnes pratiques pour la gestion de la sécurité de l'information — chapitre sur la gestion de la continuité d'activité
Le *British Standards* Institute (BSI) regroupe : • **le Royaume-Uni** • **l'Australie** • **la Nouvelle-Zélande**	AS / NZ 4360	Gestion du risque — (AS / NZ: normes Australie / Nouvelles Zélande)
	HB221	*Guide to Business Continuity Management* — supplément à la norme 4360
	AS / NZ 4390	*Records Management*
	AS / NZ 4444	*Information Security with Business Continuity Management*
***Publicly Available Standard* (PAS) Royaume-Uni et pays du Commonwealth**	PAS 56	*Guide to BCM* — (PAS — UK)

Organisation / autorité de contrôle	Norme	Description des normes
Les bulletins de l'*U.S. Office of the Comptroller of the Currency* (OCC) s'appliquent aux services financiers, en particulier aux aspects liés aux SI	Bulletin 97-23	Redémarrage des activités et planification d'urgence
	Bulletin 2001-14	Résilience
	Bulletin 2003-18	Planification de la continuité d'activité et supervision des fournisseurs de technologies
***New York Stock Exchange* (NYSE) / *Financial Industry Regulatory Authority* (FINRA)**		Livre blanc interagences publié conjointement par l'*U.S. Securities and Exchange Commission*, l'*Office of the Comptroller of the Currency* et le Conseil des Gouverneurs du Système de Réserve Fédérale sur les bonnes pratiques de continuité d'activité http://www.sec.gov/news/press/studies/2006/ soundpractices.pdf
***American National Standards Institute* (ANSI)**	ANSI / ARMA 5	*Vital Records Program (identification, management, and recovery of business critical records)* (2003). *ARMA: American Records Management Association*
***American Society for Industrial Security* (ASIS)**	ASIS GDL BC 10	*Business Continuity Guideline: A practical approach to emergency preparedness, crisis management, and disaster recovery* (2004, version préliminaire)
***U.S. National Institute of Standards and Technology* (NIST)**	NIST SP 800-34,45	*Contingency Planning Guide for IT Systems* (2002)
***U.S. National Fire Protection Association* (NFPA)**	NFPA 1600	Norme sur la gestion des catastrophes / urgences et les programmes de continuité d'activité (référencée comme une norme de continuité d'activité)

9.3 Modèle de maturité des dispositifs de gestion de la continuité

MATURITE DES PROCESSUS

Même si le modèle suivant, qui porte sur la maturité des dispositifs de gestion de la continuité d'activité, ne correspond pas précisément à ce GTAG, il est conforme au GTAG et aux pratiques et normes du secteur. Nous le mentionnons seulement comme un exemple d'évaluation de la maturité d'un programme de continuité.

Source : Protiviti Inc. (www.protiviti.com). Adapté de l'ouvrage *Capability Maturity Model: Guidelines for Improving the Software Process*, Carnegie Mellon University Software Engineering Institute, 1994.

MATURITE DES PROCESSUS

Objectif d'évaluation : Soutien apporté par l'encadrement supérieur Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	Les dispositifs de gestion de la continuité d'activité sont améliorés en permanence et systématiquement. L'encadrement supérieur utilise les moyens de gestion de la continuité d'activité pour créer d'autres facteurs d'efficience en interne et pour établir des relations stratégiques avec l'extérieur.	Les stratégies de gestion de la continuité d'activité sont alignées sur les objectifs stratégiques et les attentes des clients. L'encadrement supérieur veille à ce que la planification de gestion de la continuité opère comme une fonction clé, et soit assortie de responsabilités clairement établies.
Géré	L'encadrement supérieur a défini des critères de mesure clés, conformes à la réglementation et aux principes du secteur. Ces critères servent à mesurer l'efficacité et la qualité des dispositifs de gestion de la continuité d'activité. L'encadrement participe aux activités de test et de formation, et examine les limitations de la politique interne et les résultats des tests.	L'encadrement supérieur s'attache à gérer la qualité de l'exécution du programme de gestion de la continuité d'activité. Les critères de mesure sont établis et gérés afin de garantir la qualité des stratégies et plans de gestion de la continuité d'activité. Les objectifs afférents à la continuité d'activité sont exprimés en objectifs de performance.
Défini	Un comité directeur de gestion de la continuité est créé, et il est dirigé par un membre de l'encadrement supérieur qui n'est pas chargé des SI. C'est le comité directeur qui prend les décisions finales en matière de stratégies et de solutions de gestion de la continuité d'activité. Un budget et des ressources propres sont alloués à la gestion de la continuité d'activité afin d'en garantir l'efficacité des moyens, et des domaines y afférents sont intégrés afin de constituer une solution globale pour l'organisation.	L'encadrement supérieur participe pleinement, via un comité directeur, à la prise de décisions concernant la gestion de la continuité d'activité. Outre la politique relative à la gestion de la continuité, l'organisation a défini des cadres spécifiques pour le redémarrage de l'activité, la gestion de crise et les dispositifs de reprise des SI après sinistre, ainsi que des processus appropriés pour la maintenance, les tests et la formation.
Reproductible	L'encadrement supérieur soutient le programme de gestion de la continuité d'activité, mais sa participation à l'exécution des processus est toujours limitée. Même si la coordination de la gestion de crise, de la continuité d'activité et de la reprise après sinistre relèvent de l'encadrement intermédiaire, la coordination générale de la gestion de la continuité d'activité se fait au cas par cas ou est inexistante. Les pannes sont identifiées et corrigées après leur survenue.	L'encadrement supérieur est conscient de la nécessité de disposer de moyens de gestion de la continuité d'activité. Une politique de gestion de la continuité a été élaborée, et les mesures sont déployées en fonction des résultats d'une analyse d'impact (formelle ou informelle).
Initial	L'encadrement supérieur soutient les initiatives portant sur la gestion de la continuité d'activité de manière informelle, ou ne les soutient pas. À ce stade, les moyens de gestion de la continuité d'activité s'appuient sur des initiatives individuelles et « héroïques », et portent essentiellement sur la sauvegarde et la reprise des SI, ainsi que sur les interventions d'urgence (définition de procédures d'évacuation, par exemple).	Ces initiatives sont menées par l'encadrement intermédiaire et mises en œuvre sans financement ni ressources suffisants. Par conséquent, tous les moyens de continuité existants sont définis comme des mesures tactiques.

MATURITE DES PROCESSUS

Objectif d'évaluation : Évaluation des risques et analyse d'impact Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	Les résultats de l'évaluation des risques et de l'analyse d'impact sont déterminants pour l'amélioration continue des stratégies de reprise. La réalisation et l'examen des évaluations des risques et des analyses d'impact sont coordonnés avec les processus de gestion du changement organisationnel et technologique « *due diligence* ».	La direction générale joue le rôle de comité directeur : elle identifie et valide les conclusions relatives au risque et à l'impact. Le comité directeur recommande des changements à apporter au processus d'évaluation des risques et d'analyse d'impact, en fonction des besoins et impératifs de l'entreprise elle-même.
Géré	La direction générale soutient l'approche formelle de l'évaluation des risques et de l'analyse d'impact. Les objectifs fixés et l'efficacité sont mesurables. Les objectifs relatifs à la durée maximale d'interruption admissible (DMIA) comme à la durée maximale d'enregistrement des données (tolérance de perte de données) (DMPA) sont définis, de même que les moyens / dispositifs relatifs à la DMIA. Le processus d'évaluation des risques tient compte de l'évaluation des contrôles. Ces processus sont reproductibles et exécutés sur une base régulière.	La définition et l'élaboration des stratégies et solutions de reprise dépendent des résultats des évaluations des risques et des analyses d'impact. Ces stratégies et solutions portent sur les principaux processus et applications de SI qui sont examinés pendant les évaluations des risques et les analyses d'impact programmées à intervalles réguliers. La direction générale s'appuie sur ces résultats pour mesurer et gérer le risque au niveau de l'ensemble de l'entreprise.
Défini	Une approche plus formelle a été mise en œuvre pour l'évaluation des risques et l'analyse d'impact. La direction a choisi une approche permettant de définir des niveaux de criticité, sur la base d'une méthode visant à collecter / estimer les données relatives à l'impact sur l'entreprise. La durée maximale d'interruption admissible (DMIA) a été définie, et des stratégies sélectionnées pour répondre à cet objectif. L'encadrement examine et valide les résultats de l'évaluation des risques et de l'analyse d'impact.	Dans le cadre d'un processus formel de sélection et de mise en œuvre de la stratégie de continuité, on définit précisément une approche pour l'évaluation des risques, ou pour l'analyse d'impact. Le processus de sélection de la stratégie inclut également des objectifs de reprise directement liés aux niveaux de criticité et aux impacts sur l'organisation. L'encadrement supérieur pilote et valide ces analyses.
Reproductible	La direction a établi de manière informelle des conclusions relatives à l'évaluation des risques ainsi que des priorités pour la reprise d'activité, généralement à la suite de discussions et de sessions de facilitation, plutôt que dans le cadre d'une analyse formelle. Les priorités sont normalement axées sur le niveau des différentes composantes. La direction ne peut pas toujours justifier pleinement le financement de la stratégie de reprise, étant donné que les informations relatives à l'impact (financier ou non) restent incomplètes.	La direction de l'entreprise et / ou des SI a discuté et synthétisé les risques de non-continuité d'activité / d'indisponibilité, ou les effets attendus d'une interruption d'activité. Les objectifs de reprise préliminaires / de haut niveau ont été définis, mais pas le processus permettant de mesurer l'efficacité et la vraisemblance de ces objectifs.

MATURITE DES PROCESSUS

Objectif d'évaluation : Évaluation des risques et analyse d'impact Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
Initial	Aucune évaluation des risques ni analyse d'impact, formelle ou informelle, n'a été effectuée. La direction de l'entreprise / des SI a peut-être défini des priorités pour la reprise, mais ces conclusions sont potentiellement limitées aux niveaux d'importance perçus (en raison d'une connaissance incomplète de l'entreprise). L'organisation n'a pas estimé les conséquences (financières ou non) associées aux interruptions d'activité.	La direction de l'entreprise et / ou des SI a défini des priorités pour la reprise au cas par cas, d'après les niveaux d'importance perçus. Les scénarios de défaillance et les évaluations des contrôles restent incomplets. Aucun critère de mesure n'a été fixé.

MATURITE DES PROCESSUS

Objectif d'évaluation : Stratégie et conception de la continuité d'activité Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	Les stratégies de continuité sont examinées dans le cadre de la prise de décisions stratégiques et de la gestion du changement organisationnel / technologique. Les stratégies sont actualisées en fonction des besoins.	Des réunions stratégiques des cadres dirigeants et / ou des comités de gestion du changement conçoivent, sélectionnent et définissent le financement et la mise en œuvre des stratégies de continuité.
Géré	Les résultats de l'évaluation des risques et de l'analyse d'impact aident à sélectionner les stratégies de continuité. Un comité directeur pluridisciplinaire évalue, sur la base d'une analyse coûts / avantages, la gestion de crise, le redémarrage de l'activité et les options de reprise des SI après sinistre. Les stratégies de continuité sont examinées périodiquement, en général tous les 12 mois (après une nouvelle évaluation des risques et / ou analyse d'impact).	Un comité directeur chargé de la continuité sélectionne les stratégies sur la base d'une analyse coût / avantage. Cette équipe pluridisciplinaire évalue et sélectionne des solutions complémentaires pour l'activité et les SI.
Défini	La direction donne des indications pour la conception et la mise en œuvre de solutions ponctuelles ou de stratégies propres à un domaine. L'organisation n'a pas tiré parti des avantages associés à la sélection de stratégies à l'échelle de l'entreprise qui intègrent la gestion de crise, le redémarrage de l'activité et la reprise des SI après sinistre. L'organisation continue de se rapprocher de la mise en œuvre de stratégies qui répondent aux objectifs de reprise qui ont été définis.	L'entité chargée des systèmes d'information conserve le pouvoir de décider des stratégies de reprise après sinistre dans son domaine de compétences. La conception et la sélection des stratégies de gestion de crise et de reprise d'activité sont traitées à part, sur la base de la gestion du risque, de la sécurité, de l'audit interne, voire de l'entité chargée des systèmes d'information. La coordination entre l'entreprise et cette dernière est souvent négligée.
Reproductible	Le coût est le principal facteur qui détermine la sélection des stratégies de continuité. Les stratégies s'appuient normalement sur des sites de reprise à froid (internes ou de tiers) et sur des ressources mises à disposition par des fournisseurs. L'organisation reste exposée au risque étant donné la probabilité que les stratégies de continuité puissent échouer à atteindre des objectifs plus ambitieux.	L'organisation n'alloue pas de budget à la mise en œuvre et au maintien des stratégies de continuité. En revanche, le budget minimal est mis en œuvre et, si des financements supplémentaires sont nécessaires, ils seront considérés comme exceptionnels.
Initial	Les plans de continuité ne définissent ni la stratégie de reprise ni les ressources nécessaires, car la propriété du programme de continuité et les responsabilités y afférentes sont insuffisamment définies. L'organisation s'appuie largement sur ses fournisseurs après la crise ou l'interruption d'activité.	L'encadrement a recours à des actions au cas par cas ou à des stratégies d'intervention et de reprise non testées. La conception de ces stratégies n'est pas planifiée à l'avance. L'encadrement mise sur l'expérience, l'inventivité et la créativité dans une situation de crise.

MATURITE DES PROCESSUS

Objectif d'évaluation : Alignement des activités Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	La gestion de la continuité d'activité est prise en compte pendant les sessions d'examen de la gestion du changement, ainsi que pendant les sessions de définition de la stratégie. Cela permet à l'organisation de rester au fait de tous les changements susceptibles d'influer sur les stratégies d'intervention et de reprise existantes. Le comité directeur chargé de la gestion de la continuité d'activité se réunit sur une base trimestrielle afin d'évaluer la vraisemblance des stratégies existantes et proposées, ainsi que les dépenses par rapport à l'ensemble du secteur.	La gestion de la continuité d'activité tire parti du déploiement, dans toute l'organisation, de processus avancés portant sur la stratégie et la gestion du changement.
Géré	Lorsqu'il évalue les résultats de l'analyse d'impact et les investissements dans la stratégie de continuité, le comité directeur chargé de la gestion de la continuité tient compte des exigences des clients et / ou des accords de service formels. Les membres de l'audit interne participent aux initiatives de gestion de la continuité d'activité en tant que conseillers, et examinent le programme à la lumière des exigences imposées par la politique interne et la réglementation (le cas échéant). Lorsque l'organisation teste ses stratégies de continuité, elle teste également les solutions pour l'entreprise et pour les SI.	La gestion de la continuité d'activité est considérée comme un contrôle clé, et l'audit interne en vérifie la conformité avec la politique que l'entreprise a formalisée dans des rapports. Tous les aspects du cycle de gestion de la continuité d'activité sont mis en œuvre conjointement par les unités d'affaires et le service des SI. La gestion de la continuité d'activité sert d'avantage concurrentiel parmi d'autres initiatives de l'entreprise.
Défini	L'organisation a intégré les trois composantes de la gestion de la continuité, et un comité directeur unique chargé de la gestion de la continuité d'activité prend les décisions relatives aux stratégies et solutions. Un budget a été élaboré pour la gestion de la continuité d'activité. Les décisions sont prises en fonction d'une analyse d'impact et d'une analyse coûts / avantages formelle. Les stratégies d'intervention et de reprise internes et celles de tiers sont évaluées de façon formelle. La sélection dépend des résultats de l'évaluation des risques.	La responsabilité relative au programme de gestion de la continuité d'activité n'est plus confiée au centre de ressources informatiques, mais à un cadre à même d'exercer une influence sur l'ensemble de l'organisation. Les objectifs de la gestion de la continuité d'activité figurent parmi les objectifs de performance annuels de la direction de l'unité d'affaires concernée.

Objectif d'évaluation : Alignement des activités Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
Reproductible	L'organisation a mis en place une politique officielle pour la gestion de la continuité afin d'en orienter la conception, la mise en œuvre et l'exécution. Même si la coordination entre les processus de gestion de crise, de reprise de l'activité et de reprise des SI après sinistre est embryonnaire ou inexistante, ces processus sont en place et positionnés de manière à contribuer aux opérations d'intervention et de reprise. Une analyse d'impact (bilan d'impact sur activité) oriente la conception des stratégies de gestion de la continuité d'activité.	Même si le périmètre de la planification a été élargi à l'entreprise toute entière, la propriété et la responsabilité relèvent toujours des SI, ou bien c'est l'audit interne qui pilote la gestion de la continuité d'activité. L'analyse d'impact est le principal outil servant à concevoir les stratégies de gestion de la continuité d'activité.
Initial	Le programme de continuité de l'organisation porte sur les interventions d'urgence et / ou la reprise des SI après sinistre, mais pas sur la gestion stratégique des crises et / ou sur la reprise des processus.	Les solutions de continuité, qui peuvent se limiter aux interventions tactiques d'urgence et à la restauration des systèmes, sont pilotées par l'encadrement intermédiaire et déployées grâce au budget supplémentaire disponible (ou aux ressources internes disponibles).

MATURITE DES PROCESSUS

Objectif d'évaluation : Élaboration du plan et mise en œuvre de la stratégie Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	Les plans de gestion de crise, de reprise après sinistre et de redémarrage de l'activité sont intégrés à la planification et à la mise en œuvre. Les membres de l'équipe proviennent de plusieurs services et de plusieurs régions. Toutes les parties prenantes comprennent parfaitement ce que l'on attend d'elles. La tenue à jour du plan est étroitement intégrée aux processus de gestion du changement organisationnel.	Les réunions stratégiques des cadres dirigeants définissent les priorités de la planification et l'alignement. Des programmes standardisés de formation et de sensibilisation, portant sur la gestion de la continuité d'activité, sont diffusés à tous les participants à la planification. L'élaboration des plans incombe à ceux qui se trouvent au plus près des problèmes. Le contenu et l'alignement des plans sont validés. Des examens effectués par des experts indépendants sont programmés. Ils détermineront les changements tactiques et stratégiques.
Géré	La coordination entre les plans et les équipes chargées de la gestion de crise, du redémarrage de l'activité et de la reprise des SI après sinistre est bien définie. Les plans sont mis à jour en fonction des besoins, et non selon une fréquence minimale (par exemple annuelle). La documentation relative aux plans est examinée par une autorité centrale, ou validée par la direction générale. Les résultats des tests et l'expérience quotidienne orientent l'amélioration des plans. La documentation est correctement protégée et diffusée en fonction des besoins.	Les initiatives de planification centralisées et décentralisées sont regroupées, l'ensemble du personnel est formé à son rôle et à ses responsabilités en matière de documentation du plan. Le plan est mis à jour en fonction des changements organisationnels et technologiques, ainsi que des résultats des tests / exercices.
Défini	Les plans de gestion de crise (y compris les interventions d'urgence et la communication en cas de crise), de redémarrage des activités et de reprise des SI après sinistre sont consignés dans des rapports et donnent des informations à l'organisation. Tous les plans sont actualisés sur une base annuelle. Bien que les rôles et responsabilités soient clairement définis, la coordination entre les plans est insuffisante.	Chaque plan se voit assigner une personne responsable de son élaboration et de son actualisation (sur la base d'un modèle organisationnel). Les parties concernées définissent le contenu des plans, tandis que le contrôle de la qualité incombe au propriétaire du plan. Les opérations de mise à jour programmées déterminent la révision du plan. L'audit interne est considéré comme un partenaire pour la planification de la continuité d'activité et fait partie intégrante du processus d'amélioration continue.
Reproductible	La planification se concentre sur la documentation relative à la reprise des SI après sinistre et sur la planification des interventions d'urgence (évacuation des bâtiments, premiers secours, etc.). Il existe quelques documents relatifs à la gestion de crise, mais ils sont axés sur la gestion des incidents affectant les SI. La principale finalité de ces documents est d'éviter des commentaires émanant de l'audit. Les plans sont souvent mis à jour au coup par coup.	Les documents relatifs au plan se fondent sur les constats de l'audit interne et externe. L'équipe chargée du pilotage technologique dirige l'élaboration de la documentation du plan. Les efforts se limitent donc, pour l'essentiel, aux SI.

MATURITE DES PROCESSUS

Objectif d'évaluation : Élaboration du plan et mise en œuvre de la stratégie Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
Initial	Lorsque des plans existent, ils sont élaborés de manière isolée, et comportent trop peu d'informations sur l'entreprise et les processus technologiques. Les parties prenantes à la gestion de la continuité d'activité ne connaissent pas leur rôle ni leurs responsabilités et, parfois, pas même le rôle qu'elles doivent jouer dans les interventions et le redémarrage de l'activité. Les plans sont souvent obsolètes. Les interventions et le redémarrage font appel à la mémoire, et l'exécution est souvent réalisée au cas par cas par une poignée d'employés clés.	Ces plans pâtissent de la méconnaissance de la gestion de la continuité d'activité et ne sont pas axés sur cette gestion. Ils reposent souvent sur des matrices générales ou établies par un logiciel, et rien n'est vraiment fait pour en personnaliser le contenu. Les plans se concentrent souvent sur les interventions d'urgence et la théorie de la planification de la reprise.

MATURITE DES PROCESSUS

Objectif d'évaluation : Formation et sensibilisation Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	Toutes les strates de l'organisation comprennent parfaitement le programme de gestion de la continuité d'activité et ses conséquences sur les opérations quotidiennes. Ceux qui sont chargés des tâches afférentes à la gestion de la continuité forment leurs collègues. Les stratégies de gestion de la continuité d'activité sont évaluées en fonction de leur incidence sur la valeur de l'entreprise. La formation à la gestion de la continuité d'activité est prise en compte dans l'évaluation des performances (tableau de bord prospectif, par exemple).	Les membres de l'équipe reçoivent une formation spécifique sur la manière dont ils peuvent promouvoir la gestion de la continuité d'activité. Les responsables de cette dernière en coordonnent soigneusement les objectifs en fonction des objectifs les plus importants de l'entreprise. Les membres de l'équipe qui ont suivi une formation polyvalente ont la possibilité d'exercer des fonctions en dehors de leurs domaines de compétence habituels.
Géré	L'encadrement comprend bien l'interaction entre les différents éléments de la gestion de la continuité d'activité. Les salariés savent comment ils doivent agir dans l'immédiat si un événement survient, et nombreux sont ceux qui connaissent leurs activités depuis longtemps. Les membres de l'équipe sont à même de définir les responsabilités qui leur incombent, ainsi que la façon dont ils doivent interagir avec d'autres composantes de la gestion de la continuité d'activité et avec les objectifs de l'entreprise dans son ensemble. Les aspects relatifs à la gestion de la continuité d'activité sont pris en compte dans toutes les initiatives de l'entreprise.	Tous les membres de l'équipe sont formés à leurs tâches ainsi qu'au programme global. La direction de la gestion de la continuité d'activité fournit régulièrement une actualisation des programmes à la direction générale. Les programmes de formation et de sensibilisation sont budgétés séparément, et incluent, si nécessaire, des ressources externes. Les membres de l'équipe participent à des formations dispensées par des tiers ou sur des études de cas. La formation porte sur l'exécution du plan lors de la survenue d'un événement qui dépasse le cadre de l'entreprise.
Défini	Toutes les composantes participent à l'élaboration d'un programme structuré afin d'informer sur les buts et objectifs du plan de gestion de la continuité d'activité. Les membres du personnel qui ne font pas partie des équipes de planification et d'exécution comprennent bien ces objectifs. L'encadrement est globalement sensibilisé à l'approche multifacettes de la gestion de la continuité d'activité.	Il existe une approche structurée de la formation à la gestion de la continuité d'activité et l'encadrement de chaque secteur comprend bien le programme. Une formation aux différentes tâches requises est obligatoire pour tous les membres de l'organisation figurant sur la liste des membres de l'équipe principale et de l'équipe de renfort. Les ressources existantes, comme l'intranet ou la politique de l'entreprise en matière d'embauche, servent à sensibiliser l'ensemble du personnel au programme.

MATURITE DES PROCESSUS

Objectif d'évaluation : Formation et sensibilisation Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
Reproductible	Pour chaque élément du programme, il existe une formation ou une sensibilisation limitée, mais aucune formation polyvalente sur la gestion de crise, le redémarrage de l'activité et la reprise après sinistre. Il se peut que certaines composantes du programme disposent de moyens de sauvegarde désignés, et les membres de l'équipe participent à la communication informelle portant sur le programme.	L'encadrement intermédiaire ayant la responsabilité tactique des éléments du programme, il est conscient du risque qu'il y a à confier à une seule personne une tâche critique de gestion de la continuité d'activité. Les tests et / ou mises à jour de la gestion de la continuité d'activité constituent un sujet récurrent dans les réunions du personnel des différents services. Une formation formelle sur des tâches spécifiques est dispensée à ceux qui ont l'obligation de les exécuter, mais rien d'autre. La formation est limitée à la participation à des exercices.
Initial	Il n'existe pas de programme formel de formation ou de sensibilisation. Seuls ceux qui en sont directement responsables connaissent les buts et les objectifs du programme. Il n'existe pas de formation portant conjointement sur la gestion de crise, le redémarrage de l'activité et la reprise après sinistre. Les questions de réglementation orientent les initiatives de formation et de sensibilisation.	La formation est le fruit d'une combinaison de « silos » de planification. Elle est en place lorsque des efforts individuels sortant de l'ordinaire constituent le fondement de la gestion de la continuité d'activité. Dans ce cas, la formation est limitée aux interventions d'urgence.

MATURITE DES PROCESSUS

Objectif d'évaluation : Réalisation de tests et tenue à jour du plan Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	Les tests de la continuité d'activité sont inopinés. Les simulations sont définies d'après les risques probables identifiés lors d'une évaluation des risques. L'efficacité des tests est principalement mesurée par une reprise attendue. Des services entiers sont transférés sur un site de remplacement (systèmes et ressources de secours) pendant une période définie. Les partenaires commerciaux et les fournisseurs participent aux tests. Les actualisations du plan sont automatiquement intégrées via un processus de mise à jour.	Les membres de l'équipe reçoivent une formation poussée et leur intervention consiste en une simple réaction. En préparation des tests, une planification minimale est réalisée en secret par une poignée d'individus. Les membres de l'équipe d'intervention et de reprise s'appuient très peu sur les documents relatifs au plan, en dehors de certaines procédures techniques ou listes de contacts qui sont à jour. Des outils automatisés servent à l'actualisation du plan et veillent à ce qu'il reflète les opérations de l'entreprise.
Géré	La continuité d'activité de l'entreprise et des SI est régulièrement testée dans son intégralité. Des simulations sont définies d'après les risques probables identifiés lors d'une évaluation des risques. L'efficacité des tests est mesurée par la rapidité de reprise des composantes ou des fonctions critiques : connectivité, fonctionnement des applications ou traitement des transactions. Des plans sont maintenus hors site et des mises à jour effectuées à l'issue des tests. L'audit interne observe les exercices et veille à ce que les plans soient mis à jour.	La planification des tests englobe la gestion de crise, le redémarrage de l'activité et la reprise des SI après sinistre. Les membres de l'équipe reçoivent une formation pluridisciplinaire portant sur toutes les procédures pertinentes. Ils s'appuient peu sur la documentation relative au plan, même si les inexactitudes au niveau des procédures et de la liste de contacts doivent être rectifiées rapidement. L'audit interne pilote la planification des tests, leur exécution et les actions qui résultent des tests. La mise à jour du plan incombe aux propriétaires des processus, sous la supervision de l'audit interne.
Défini	Les tests portant sur la continuité et la reprise des SI après sinistre sont parfois effectués ensemble, mais ils se concentrent généralement sur la reprise des différentes composantes. Les procédures de continuité font l'objet de discussions dans le cadre de sessions de facilitation, afin de repérer les lacunes de la planification. L'efficacité des tests est principalement mesurée par le délai nécessaire à la reprise et à l'aune de l'efficacité globale. Des services entiers sont transférés sur un site de remplacement pendant une période définie, avec des systèmes de secours. Les enseignements qui en sont tirés sont présentés dans des rapports, et les mises à jour du plan sont effectuées selon un échéancier.	Le personnel de l'entreprise et des SI procèdent régulièrement à des tests de continuité portant sur la reprise des processus et des SI. Les utilisateurs testent la connectivité et l'accès aux applications. La planification de ces tests est réalisée à grande échelle et fait intervenir du personnel interne et des personnes extérieures en tant que facilitateurs et / ou contrôleurs. L'audit interne participe aux exercices et surveille le processus d'actualisation des plans en fonction des résultats des tests. Les mises à jour des plans incombent au propriétaire du processus, avec une coordination centrale.

MATURITE DES PROCESSUS

Objectif d'évaluation : Réalisation de tests et tenue à jour du plan Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
Reproductible	Les tests sont axés sur la reprise des SI après sinistre et peuvent nécessiter une validation, par l'utilisateur final, de l'environnement rétabli et / ou des résultats des tests. Dans certaines organisations, l'encadrement procède à des exercices reposant sur des scénarios ou à des exercices sur table afin d'évaluer ses dispositifs de gestion de crise. Les tests de reprise des SI après sinistre sont axés sur la reprise des composantes. L'audit interne examine les procédures de continuité, si cette fonction existe. La mise à jour des plans s'effectue selon un échéancier.	Le personnel des SI procède régulièrement à des tests portant sur la reprise des SI après sinistre et la reprise des composantes. La planification de ces tests est réalisée à grande échelle et fait intervenir du personnel interne et des personnes extérieures en tant que facilitateurs et / ou contrôleurs. L'audit interne participe aux exercices et surveille le processus d'actualisation des plans en fonction des résultats des tests. Un collaborateur est responsable de la mise à jour du plan.
Initial	Les tests portant sur les composantes des SI ont lieu en interne, au sein du service des SI. Le management n'en est que vaguement informé et les utilisateurs n'y participent pas. Aucun calendrier formel n'est établi pour les tests, et les résultats ne sont que rarement présentés dans un rapport. Les tests ne donnent pas lieu à des modifications ou à des améliorations de la documentation relative aux procédures d'intervention / de reprise. Il est possible que les plans ne soient pas bien tenus à jour car le processus de gestion de la continuité d'activité est nouveau.	On constate des réussites dans la planification de la continuité d'activité, en général limitées aux SI, lorsque des efforts extraordinaires sont déployés. La formation, lorsqu'elle existe, est limitée aux interventions d'urgence (premiers secours, évacuation, etc.) et à la reprise des composantes des SI. Les mises à jour du plan incombent aux propriétaires des processus et ne suivent pas un processus standard piloté.

MATURITE DES PROCESSUS

Objectif d'évaluation : Suivi et audit de la conformité Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
En cours d'optimisation	L'audit interne, la gestion des risques et le service juridique examinent régulièrement la documentation relative au plan et apportent leur soutien à l'audit externe des dispositifs de gestion de la continuité, notamment des tests. L'organisation participe à des discussions sectorielles sur la conformité à la réglementation et examine régulièrement les analyses comparatives. Une évaluation des risques et une analyse d'impact sont réalisées et régulièrement actualisées afin que les plans reflètent la réalité et l'environnement réglementaire de l'entreprise.	L'entreprise prend les devants en établissant des contacts avec les autorités de réglementation. Une équipe spécialisée pilote les activités de gestion de la continuité, avec le soutien d'une équipe pluridisciplinaire (entreprise / technologie), qui regroupe l'audit interne et des prestataires extérieurs de services spécialisés. Une évaluation des risques (par site) et une analyse d'impact (par processus) doivent être menées et servir de base pour l'élaboration des plans. Elles doivent aussi être périodiquement actualisées.
Géré	Les équipes pluridisciplinaires, qui incluent le service juridique et l'audit interne, procèdent à des évaluations régulières de l'environnement professionnel et de la réglementation. À un titre ou à un autre, l'audit interne, la gestion des risques et le service juridique examinent également chaque année la documentation relative au plan. Une évaluation des risques et une analyse d'impact permettent de garantir que les plans reflètent bien la réalité de l'entreprise et sont axés sur les risques et les conséquences les plus probables et les plus graves.	Une équipe spécialisée pilote les activités de gestion de la continuité, avec le soutien d'une équipe pluridisciplinaire (entreprise / technologie), qui regroupe l'audit interne et des prestataires extérieurs de services spécialisés. Une évaluation des risques (par site) et une analyse d'impact (par processus) doivent être menées et servir de base pour l'élaboration des plans. Elles doivent aussi être périodiquement actualisées. L'audit interne se concentre sur l'exécution du programme de gestion de la continuité d'activité, et non sur le contenu du plan.
Défini	Les règles de gestion de la continuité d'activité sont prises en compte et incluses dans les plans *ad hoc*. C'est au service du contentieux qu'il incombe de surveiller l'évolution de la réglementation et de communiquer avec le comité directeur chargé de la gestion de la continuité d'activité. L'audit interne pilote la révision du plan et intervient lorsqu'une modification de la réglementation nécessite une mise à jour de la documentation. Une évaluation des risques et une analyse d'impact qui tiennent compte du cadre réglementaire ont été réalisées au cours des deux dernières années.	Une petite équipe pluridisciplinaire est en place, et l'audit interne participe activement à ses opérations. Une évaluation des risques (par site) et une analyse d'impact (par processus) sont menées et servent de base à l'élaboration du plan et à l'identification de l'impact de la réglementation sur l'élaboration du plan.
Reproductible	Les règles de gestion de la continuité d'activité sont prises en compte et incluses dans les plans, lorsque c'est possible financièrement. L'audit interne examine la pertinence de la documentation en fonction d'un plan d'audit à long terme, et peut demander la preuve que le plan a bien été testé.	L'audit interne, la gestion du risque ou le service juridique communiquent régulièrement les mises à jour portant sur la réglementation à l'équipe ou aux responsables de la gestion de la continuité d'activité.

MATURITE DES PROCESSUS

Objectif d'évaluation : Suivi et audit de la conformité Évaluation de la maturité		
	Caractéristiques des dispositifs	**Méthodologie**
Initial	La réglementation ou les normes sectorielles portant sur la gestion de la continuité d'activité sont rarement prises en compte et intégrées aux plans y afférents, ou jugées trop coûteuses à mettre en œuvre. L'audit interne se contente de veiller à ce que les plans de reprise des SI après sinistre fassent l'objet de rapports.	Il existe un processus de planification de la reprise des SI après sinistre. Un service d'audit interne est en place, et la reprise après sinistre figure dans le plan d'audit annuel ou semestriel.

Glossaire

CBCP : Certified Business Continuity Professional

DRI : DRI International

SI : Système(s) d'information

MBCP : Master Business Continuity Professional

RPO (DMPA : Délai maximum de perte acceptable)

RTO (DMIA : Durée maximale d'interruption admissible)

À propos des auteurs

David Everest, CISA

David Everest est l'un des vice-présidents chargé de l'examen des risques technologiques (*Technology Risk Review*) chez KeyBank à Cleveland (Ohio, États-Unis). David Everest a pour mission principale de conseiller la division technologique de KeyBank. Ses domaines de spécialité sont les projets d'infrastructure et de mise en réseau. Avant de rejoindre cette banque, il a travaillé comme auditeur des technologies chez General Motors à Detroit (Michigan, États-Unis). Disposant d'une solide expérience des SI, tant sur le plan technique que stratégique, il a travaillé dans des centres de ressources informatiques et dirigé des services informatiques.

David Everest est titulaire d'un *BS in Computer Information Systems* du Baldwin Wallace College de Berea (Ohio) et d'un *MBA* de la Weatherhead School of Management de la Case Western Reserve University de Cleveland.

Roy E. Garber, CIA, CISA

Roy Garber est directeur du développement des applications (*Application Development*) chez Safe Auto Insurance Co. Il est responsable du bureau de gestion de projet et des solutions d'informatique d'entreprise. Il est également actuellement chargé de la mise en œuvre des principes de gouvernance et des bonnes pratiques dans le domaine des SI.

Roy Garber travaille depuis plus de vingt ans dans la gestion du risque informatique, financier et opérationnel. Il a travaillé comme auditeur interne dans une compagnie d'assurance internationale, où il dirigeait les services d'audit informatique des entreprises. Il a aussi géré, en qualité d'auditeur externe, les contrats de services d'assurance informatique dans des grandes, moyennes et petites entreprises et a travaillé en partenariat avec l'encadrement de ses clients afin de les aider à gérer les risques informatiques.

Michael Keating

Mickael Keating est responsable de la gestion de la continuité d'activité chez Navigant Consulting. Auparavant, il a occupé divers postes de direction dans le secteur de la gestion de crise et de la continuité d'activité. Il a notamment travaillé près de quatre ans comme directeur des bureaux du Midwest du plus gros courtier d'assurance au monde et quatre ans comme directeur de la branche Sud-Est pour un cabinet d'audit interne et de conseil de premier plan. Mickael Keating a également développé le programme BICEPP (*Business and Industry Council for Emergency Planning and Preparedness*) de la Croix-Rouge américaine, premier programme de ce type à aider les organisations à se préparer aux catastrophes.

Il est spécialisé dans les programmes de continuité d'activité à l'échelle de l'entreprise et a aidé des clients de toutes tailles et de tous secteurs à se préparer afin de minimiser les conséquences des interruptions d'activité.

Brian Peterson

Brian Peterson dirige l'équipe consultative mondiale sur la gestion du risque d'information (*Global Information Risk Management Consultant Team*) chez Chevron Corp. Sa mission consiste à conseiller les entreprises Chevron à travers le monde. Il est actuellement chargé de diriger des consultants spécialisés dans la gestion des risques dans quatre pays. Brian Peterson travaille depuis plus de 25 ans dans l'informatique, la gestion de projet et la gestion des risques. Il a travaillé dans 55 pays pour aider les unités d'affaires de Chevron dans divers programmes de gestion des risques. Brian Peterson a mis au point plusieurs outils et processus qui sont utilisés par l'ensemble du groupe Chevron pour gérer les risques liés à l'information.

Brian Peterson a contribué à la création du consortium LOGIIC (*Link the Oil and Gas Industry to Improve Cyber-security*), un partenariat entre les pouvoirs publics et le secteur, dont il est actuellement le gestionnaire de projet.

Réviseurs

L'IIA remercie les individus et organisations suivantes pour leurs précieux commentaires et la valeur qu'ils ont apportés au présent guide :

- Professional Practices Committee:
  - Advanced Technology Committee
  - Board of Regents
  - Committee on Quality
  - Internal Auditing Standards Board
  - Professional Issues Committee
  - Ethics Committee
- Lily Bi, The IIA
- Larry Brown, The Options Clearing Corp., États-Unis
- Faisal R. Danka, Londres, Royaume-Uni
- Christopher Fox, ASA, Delta, New York, États-Unis
- Nelson Gibbs, Deloitte & Touche, LLP, États-Unis
- Markus Künzel, Medizinische Universität Wien, Autriche
- Lemuel Longwe, Ernst & Young Chartered Accountants, Zimbabwe
- Steve Mar, Resources Global, États-Unis

- Tom Margosian, Ford Motor Co., États-Unis
- James Reinhard, Simon Property Group Inc., États-Unis

Gestion de la continuité d'activité

Ce guide pratique d'audit des technologies de l'information (GTAG) montre comment la gestion de la continuité d'activité est conçue pour permettre aux dirigeants d'entreprise de gérer le niveau de risques auquel l'organisation pourrait être confrontée s'il se produisait un événement perturbateur, d'origine naturelle ou anthropique, affectant l'opérabilité globale de l'organisation. Ce guide porte sur la planification de la reprise après sinistre destinée à assurer la continuité de l'infrastructure des technologies de l'information et des applications critiques de l'entreprise.

Les responsables de l'audit interne doivent informer les chefs d'entreprise des risques, contrôles, coûts et avantages liés à l'adoption d'un programme de gestion de la continuité d'activité. Même si les récentes catastrophes survenues dans le monde ont incité certains dirigeants à prêter attention à ces programmes, la mise en œuvre de ces dispositifs est loin d'être universelle. La principale mission des responsables de l'audit interne est d'amener les dirigeants d'entreprise à faire de la gestion de la continuité une priorité. S'ils sont pour la plupart prêts à admettre que la gestion de la continuité est une bonne idée, nombreux auront du mal à trouver le budget nécessaire pour financer le programme ainsi qu'un sponsor qui aura le temps d'en assurer la réussite. La *gestion de la continuité d'activité* aidera le responsable de l'audit interne à sensibiliser l'entreprise aux risques et à soutenir la direction lorsqu'elle élaborera et tiendra à jour un programme de continuité d'activité.

Pour attribuer une note à ce guide ou formuler des commentaires, veuillez vous rendre sur www.theiia.org/guidance/technology/.